



Top Threats
Working Group



Survey Report

Top Threats to Cloud Computing 2026

The permanent and official location for the Top Threats Working Group is cloudsecurityalliance.org/research/working-groups/top-threats

© 2026 Cloud Security Alliance – All Rights Reserved. You may download, store, display on your computer, view, print, and link to the Cloud Security Alliance at cloudsecurityalliance.org subject to the following: (a) the draft may be used solely for your personal, informational, non-commercial use; (b) the draft may not be modified or altered in any way; (c) the draft may not be redistributed; and (d) the trademark, copyright or other notices may not be removed. You may quote portions of the draft as permitted by the Fair Use provisions of the United States Copyright Act, provided that you attribute the portions to the Cloud Security Alliance.

Acknowledgments

The Top Threats Working Group aims to provide organizations with an up-to-date, expert-informed understanding of cloud security risks, threats, and vulnerabilities in order to make educated risk-management decisions regarding cloud adoption strategies.

CO-CHAIRS

Vic Hargrave
Michael Roza
Jon-Michael Brook
Alex Getsin

REVIEWERS

Ravindra Annam
Srinivasu Bongu
Harith Gaddamanugu
Matthieu Gaillard-Midol
Nihar Kalyanam
Shantanu Savant
Gaurav Vikram Singh
Nishanth Sirikonda
Chris Pepper

CONTRIBUTORS

Annunay Bhatt
Jon-Michael Brook
Randall Brooks
Hilary Chan
Scott Fuhriman
Vic Hargrave
Sathish Holla
Michael Morgenstern
Michael Roza
Mark Szalkiewicz
Oren Yeger

CSA GLOBAL STAFF

Andy Ruth
Stephen Smith
Stephen Lumpe

Table of Contents

- Acknowledgments 3
- Executive Summary..... 5
- The Survey 8
- Meet the Top Threats 10
 - Security Issue 01: Inadequate Identity and Access Management 12
 - Security Issue 02: AI-Enhanced Attacks 18
 - Security Issue 03: Insecure Third-Party Resources 26
 - Security Issue 04: Insecure Interfaces and APIs 33
 - Security Issue 05: Misconfiguration and Inadequate Change Control..... 40
 - Security Issue 06: AI System Compromise..... 47
 - Security Issue 07: Advanced Persistent Threats..... 54
 - Security Issue 08: Lacking Cloud Security Strategy and Governance 60
 - Security Issue 09: Insecure Software Development 68
 - Security Issue 10: Accidental Cloud Data Exposure..... 73
 - Security Issue 11: System Vulnerabilities..... 79
- Conclusion and Future Outlook 85
- Appendix 1: Technical/Business Impacts and Key Takeaway Sections Content..... 87

Executive Summary

The Top Threats to Cloud Computing Survey Report 2026 show a decisive change in cloud security priorities. Identity, artificial intelligence, third-party resources, and APIs now dominate the cloud threat landscape; while traditional infrastructure concerns continue to decline in relative importance. Most notably, two new AI-related issues, AI-Enhanced Attacks and AI System Compromise, entered the Top Threats rankings in second and sixth place, respectively, highlighting the growing influence of AI on both attack methods and defensive strategies. Although both issues involve AI, they address different risks: AI-Enhanced Attacks focuses on the use of AI to improve or automate attacks, while AI System Compromise focuses on AI systems themselves as assets that can be compromised, manipulated, or abused. This Top Threats report aims to raise awareness of cloud threats, vulnerabilities, and risks.

For this installment we surveyed 507 industry experts on security issues in the cloud industry. Our respondents identified 11 important security issues in their cloud environments this year. The Top Threats Working Group used the survey results and its expertise to create the “Top Threats to Cloud Computing 2026” report.

Rank	2026	2024
1	Inadequate Identity and Access Management <i>(Identity & Access Management in 2024 survey)</i>	Misconfiguration & Inadequate Change Control
2	AI (Artificial Intelligence)-Enhanced Attacks <i>(new in 2026)</i>	Identity & Access Management
3	Insecure Third-Party Resources	Insecure Interfaces and APIs
4	Insecure Interfaces and APIs	Inadequate Selection/Implementation of Cloud Security Strategy
5	Misconfiguration & Inadequate Change Control	Insecure Third-Party Resources
6	AI System Compromise (new in 2026)	Insecure Software Development
7	Advanced Persistent Threats	Accidental Cloud Disclosure
8	Lacking Cloud Security Strategy & Governance <i>(Inadequate Selection/Implementation of Cloud Security Strategy in 2024 survey)</i>	System Vulnerabilities
9	Insecure Software Development	Limited Cloud Visibility/Observability
10	Accidental Cloud Data Disclosure	Unauthenticated Resource Sharing
11	System Vulnerabilities	Advanced Persistent Threats

Note: The rankings shown for 2026 and 2024 represent the relative position of each security issue in the respective survey year. Entries appearing on the same row are not direct one-to-one mappings between years.

OBSERVATIONS

The 2026 survey results show identity, AI, software supply chains, and interconnected cloud ecosystems displacing traditional infrastructure as the primary security concerns. Issues tied to the underlying cloud infrastructure and cloud service providers ranked below the Top 11 this year. Issues such as denial-of-service attacks, shared technology vulnerabilities, CSP data loss, Unauthenticated Resource Sharing, and Limited Cloud Visibility/Observability were also rated below the Top 11 this year.

The most notable development in the 2026 results was the emergence of AI as both an enabler of attacks and a target. AI-Enhanced Attacks and AI System Compromise entered the rankings at second and sixth place, respectively, reflecting growing concern about the impact of AI on cloud security. AI is not an emerging concern — it is the current one. Autonomous agents, multi-agent systems, and MCP-based integrations are introducing attack surfaces that most cloud security programs were not built to address.

Several themes emerged from the survey results:

- **Inadequate Identity and Access Management (IAM):** IAM ranked first in 2026. Respondents highlighted replay attacks, impersonation, excessive permissions, non-human identities, poorly managed certificates and cryptographic keys, and excessive trust in federated relationships. The continued adoption of Zero Trust approaches reflects the central role which identity now plays in cloud security.
- **AI-Enhanced Attacks:** This new issue entered the rankings in second place. Respondents expressed concern that attackers are using AI to improve phishing, reconnaissance, malware development, social engineering, vulnerability discovery, and attack automation. AI is lowering the barrier to entry for attackers, while making their activity harder to distinguish from legitimate behavior. The capabilities of Mythos and similar systems, where currently discovery speed outpaces remediation, have contributed dramatically to this threat.
- **Insecure Third-Party Resources:** Third-party risk rose to third place, reflecting growing dependence on SaaS providers, software packages, external APIs, AI models, managed services, and cloud marketplaces. Third place means organizations are discovering this risk too late. They are losing ground to it.
- **Insecure Interfaces and APIs:** APIs and interfaces ranked fourth as cloud-native architectures, microservices, and API-driven integrations continue to expand. Weak authentication, excessive permissions, insecure API design, and inadequate monitoring remain common sources of exposure.
- **Misconfiguration and Inadequate Change Control:** Misconfiguration remained in the Top 5 despite years of awareness. Multi-cloud environments, infrastructure-as-code (IaC), Kubernetes, serverless functions, AI services, and increasing automation continue to increase configuration complexity and the likelihood of error.

- **AI System Compromise:** This new issue entered the rankings in sixth place. Respondents expressed concern that AI systems themselves have become attack targets. Threats such as prompt injection, model theft, data poisoning, insecure AI integrations, agent compromise, and attacks against training and inference environments are not variations of known cloud risks. Most cloud security programs have no controls specifically designed for any of them.
- **Lacking Cloud Security Strategy and Governance:** The environments organizations are trying to govern in 2026 bear little resemblance to the ones their governance frameworks were designed for.

The 2026 results make the priorities clear: identity, AI, third-party ecosystems, and APIs. Everything else is bringing up the rear.

TARGET AUDIENCE

This report is designed to support security program planning, risk prioritization, and governance investment decisions across cloud and AI environments. This survey-based research also provides compliance, risk, technology, and information security staff, as well as executive management, with insights into current technology trends and high-priority cloud security considerations.

The Survey

When creating the “Top Threats to Cloud Computing 2026” survey report, the CSA Top Threats Working Group conducted research in two stages. Both stages used surveys to gather the thoughts and opinions of cybersecurity professionals concerning the most relevant threats, vulnerabilities, and risks of security issues to cloud computing, with the ultimate goal of identifying the Top Threats for 2026. During the first stage the group created a shortlist of cloud security issues through an online survey of the working group’s members. The group started with the 11 threats from the previous report, [Top Threats to Cloud Computing 2024](#), and added 12 new issues through discussion. The group then reviewed the 23 issues in a series of meetings, asking working group members to indicate the importance of each issue to their organizations and other familiar organizations. These 23 issues were presented in the survey.

During the second stage of the research, the group’s main goal was to rank by importance the list of 23 security issues, based on an online survey of 507 security professionals. The group chose a 10-point sliding scale to reflect the importance of each issue. The survey participants were instructed to rate each issue on a scale of 1 to 10, with 1 being “Not very important” and 10 being “Most important.” The points for each category were totaled and averaged. The security issues were then ranked according to their mean score. The working group used these scores to arrive at the prioritized Top 11 Threats below.

Survey Results Rank	Survey Average Score	Issue Name
1	7.95	Inadequate Identity and Access Management
2	7.91	AI-Enhanced Attacks
3	7.85	Insecure Third-Party Resources
4	7.83	Insecure Interfaces and APIs
5	7.77	Misconfiguration and Inadequate Change Control
6	7.71	AI System Compromise
7	7.66	Advanced Persistent Threats
8	7.64	Lacking Cloud Security Strategy & Governance
9	7.56	Insecure Software Development
10	7.48	Accidental Cloud Data Disclosure
11	7.45	System Vulnerabilities

With the 11 Top Threats identified and ordered, the working group analyzed each issue.

Each analysis describes:

- A. The issue
- B. Technical impacts
- C. Business impacts
- D. Key takeaways
- E. Anecdotes, using real-world examples
- F. Reference to the relevant section of [CSA's Security Guidance for Critical Areas of Focus in Cloud](#)
- G. Computing v5 domain guides, and
- H. The relevant mitigating controls in [CSA's Artificial Intelligence Cloud Controls Matrix v1.1 \(AICM\)](#)

Finally, the overall methodology aligns with the Top Threats methodology presented in [Appendix 1: Technical/Business Impacts and Key Takeaway Sections Content](#).

MEET THE TOP THREATS



SECURITY ISSUE 01

Inadequate Identity and Access Management

Inadequate IAM stems from misconfigured trust relationships, weak credentials, and sprawling machine identities, letting attackers slip past authentication undetected. Unifying IAM tooling and enforcing least privilege remain the primary defenses.

SECURITY ISSUE 02

AI-Enhanced Attacks

AI-enhanced attacks exploit misconfigured controls and exposed management planes to identify and weaponize vulnerabilities at machine speed. Attackers have weaponized newly published flaws in under 22 minutes.



SECURITY ISSUE 03

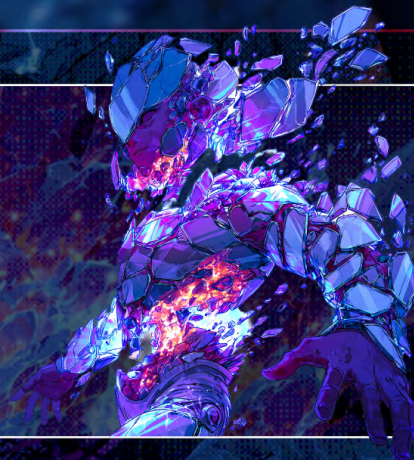
Insecure Third-Party Resources

Insecure third-party resources span SaaS tools, APIs, and CI/CD pipelines, where one compromised vendor can breach many downstream organizations. Managing this exposure, known as C-SCRM, is now a board-level concern.

SECURITY ISSUE 04

Insecure Third-Party APIs

Insecure interfaces and APIs arise from broken authentication and poorly governed machine identities such as API keys and tokens, which caused 52% of this year's API breaches.



SECURITY ISSUE 05

Misconfiguration and Inadequate Change Control

Misconfiguration stems from weak change control, excessive permissions, and thin logging, and often goes undetected until a breach forces review. It caused 29.4% of this year's cloud access breaches.



SECURITY ISSUE 06

AI System Compromise

AI System Compromise is the exploitation of models, prompts, or connected tools, often without breaching the host itself. A single prompt injection let a worm spread through GitHub Copilot in 2025.



SECURITY ISSUE 07

Advanced Persistent Threats

Advanced Persistent Threats are sustained, often state-sponsored campaigns that target privileged accounts and OAuth tokens for lasting cloud access. In 2026, the actor Sapphire Sleet compromised an npm package to harvest developer credentials.



SECURITY ISSUE 08

Lacking Cloud Security Strategy and Governance

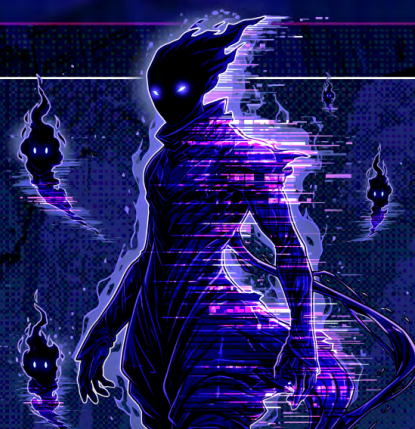
A lacking cloud security strategy leaves identities, data flows, and AI tools ungoverned, letting adoption outpace the visibility needed to manage it. Machine identities now outnumber human ones 100 to 1.



SECURITY ISSUE 09

Insecure Software Development

Insecure software development stems from weak coding practices and overprivileged automation identities, exposing credentials that let attackers reach cloud control planes. Hardening CI/CD tooling and eliminating hard-coded secrets remain key defenses.



SECURITY ISSUE 10

Accidental Cloud Data Exposure

Accidental cloud data exposure stems from misconfiguration and unauthorized Shadow AI use, with nearly half of cloud databases now publicly accessible. Most breaches trace back to convenience winning out over security.



SECURITY ISSUE 11

System Vulnerabilities

System vulnerabilities in cloud infrastructure compromise data and disrupt operations. Common causes include misconfiguration, zero-days, and weak credentials. Patching and monitoring remain essential defenses.

Inadequate Identity and Access Management



Identity & Access Management (IAM) ensures only authorized users can access the resources they need by proving who or what they claim to be. IAM is pivotal in defining and managing user roles, access privileges, and the specific conditions under which these privileges are allocated or rescinded. Despite its critical role, IAM presents ongoing challenges in cybersecurity due to its complexity and the evolving nature of cyber threats. Key components including user authentication, authorization, Single Sign-On (SSO), Multi-Factor Authentication (MFA), and activity monitoring are integral to IAM's effectiveness. However, the intricacies and dynamism of these features can introduce vulnerabilities, especially if not implemented, configured, updated, or monitored correctly. As cyber threats become more sophisticated, securing sensitive information against unauthorized access becomes increasingly daunting, making the robust implementation and continual refinement of IAM strategies indispensable in fortifying cybersecurity defenses.

Managing identities and access in cloud environments can be complex and risky. Different cloud providers have unique systems, which can lead to mistakes and security gaps. When users create and manage their accounts and resources, these discrepancies can result in excessive permissions and misconfigured settings, increasing security risks and leading to privilege sprawl. With centralized IAM system monitoring, issue response is easier, while inconsistent policies further complicate security efforts.

The modern cloud landscape has also seen an explosion of Non-Human Identities (NHIs), such as service accounts, API keys, and automated bots, which now vastly outnumber human users. Unlike human identities, these machine identities often lack standardized lifecycles and are prone to over-permissioning to ensure that automated workflows run uninterrupted. AI agents have also emerged as a major category of NHIs. This represents a shift in the underlying question IAM must answer. Traditional IAM asks who this entity is but agentic systems require asking whose authority

is being exercised, under what constraints, and for how long. An agent's identity is necessary but not sufficient. Verifying an agent's identity doesn't tell you what it was actually authorized to do on a human's behalf, or whether that authorization still holds. Therefore organizations should extend identity governance programs to include agent lifecycle management, least-privilege enforcement, credential rotation, and continuous authorization validation. Without a dedicated strategy to govern these machine-to-machine interactions NHIs represent a massive, invisible attack surface.

Prominent concerns have historically revolved around misconfigured trust relationships, bypassed security controls, poorly enforced access policies, and improperly managed or exposed credentials. Increasingly, cloud compromises involve abuse of trusted relationships between identities, applications and cloud services — rather than direct credential compromise. As organizations expand third-party integrations, automated workflows and governance of trusted relationships are becoming as critical as authorization and authentication themselves.

NHIs have enabled attackers to shift their tactics accordingly. Instead of targeting traditional passwords modern cybercriminals increasingly focus on stealing active session tokens, hijacking over-privileged automation, and exploiting vulnerabilities in misconfigured authentication flows. This underscores a major shift where today's threats aren't just credential theft, concerns are shifting to the exploitation of valid post-authentication sessions. Organizations must pivot their IAM priorities from initial access controls to continuous, post-trust session protection to mitigate this top-tier risk.

TECHNICAL IMPACT

Confidentiality

- *System Access & Data Disclosure:* Weak authentication, stolen credentials, excessive permissions, and misconfigured trust boundaries allow attackers to bypass security perimeters; which leads to unauthorized users gaining access to sensitive data.
- *AI and Cloud Exposure:* Misconfigured storage, APIs, vector databases, or logging systems—often accessed via over-privileged service accounts—can expose highly sensitive information. For more detail, refer to Security Issue 10: Accidental Cloud Data Exposure.
- *Exposure of secrets and credentials:* Inadequate operation of identity objects, secure certificates, encryption keys, secrets, service accounts, access tokens and API keys allow unauthorized users to access across cloud environments.

Integrity

- *Unauthorized Modification:* Inconsistent IAM policies and a lack of Conditional Access enforcement allow attackers to escalate privileges and manipulate critical configurations.
- *Destruction or Corruption of Data:* Improperly controlled changes or misconfigured workflows may corrupt or destroy datasets, model artifacts, or critical system data; affecting system integrity or recoverability.
- *System Trust:* If an attacker maneuvers in an environment with elevated privileges, they can permanently compromise the integrity and recoverability of the entire environment.

Availability

- *Loss of Data or Service Availability and Operational Outages:* Misconfigured access to any aspect or element in the environment may result in unavailability, degraded performance, or outages of cloud or AI data and services.
- *Service Disruption:* Mismanaged identity lifecycles that bypass Zero Trust controls can be exploited to lock out legitimate administrators or shut down mission-critical services.
- *Resource Exhaustion:* Overprivileged identities can trigger events that degrade performance or cause complete outages of cloud-native and AI services.

BUSINESS IMPACT

Operational

- *Service Outage:* Exploitation of overprivileged service accounts or “break-glass” credentials can lead to a partial or complete shutdown of cloud infrastructure services or AI inference pipelines, disrupting or halting core business operations.
- *Feature Delay:* Feature updates may be delayed to remediate software exploits.
- *Remediation Debt:* The discovery of pervasive IAM misconfiguration (such as unrotated keys or insecure OIDC trusts) forces a shift from innovation to emergency remediation, resulting in significant delays to product roadmaps and feature updates.

Financial

- *Lost Revenue:* Financial losses can occur due to service disruption, service restoration, customer dissatisfaction, or legal actions including regulatory fines & legal costs.
- *Non-compliance:* Failure to adequately secure identity and access controls can lead to non-compliance with regulatory requirements such as GDPR, CCPA, and industry-specific regulations including PCI DSS.
- *Regulatory Fines & Legal Costs:* Inadequate control over NHI often leads to non-compliance with evolving mandates such as GDPR, CCPA, and AI-specific regulations, which can trigger fines and costly class-action litigation.

Compliance

- *Regulatory / Compliance Violations:* Weak IAM controls and unsecured Non-Human Identities violate global data protection mandates, including GDPR and CCPA. Recurring IAM failures cast doubt on an organization’s ability to adhere to security standards such as ISO/IEC 27001, SOC 2, and FedRAMP. The ability to achieve or retain these authoritative certifications might be delayed or forfeited.
- *Audit Findings:* Identity sprawl, unrotated keys, misconfigured trust, and missing access policies can cause failed assessments.
- *Policy Non-conformance:* Storing plaintext credentials and using long-lived tokens directly violate corporate Zero Trust baselines. Neglecting least-privilege enforcement breaches internal governance policies and contractual security SLAs with clients and partners.

Reputational

- *Company Reputation:* Damage to the organization's public image, business, and brand value.
- *Customer Reputation:* Clients relying on weakly secured API cloud services may experience data breaches and service interruptions, which can negatively impact their reputations.
- *Downstream Customer Fallout:* Organizations providing SaaS or API-driven services risk "collateral damage" to their clients.

KEY TAKEAWAYS

- **Unify IAM Solutions:** Use IAM solutions that provide strong authentication, centralized management, and visibility across multiple cloud providers.
- **Enforce Least Privilege to Limit Impact Scope:** Ensure entities have only the access rights needed to perform their tasks. Controlling impact scope helps mitigate potential breaches. Rigidly apply the principle of least privilege to both human and automated workloads. Eliminating "privilege sprawl" and over-permissioned automation is the most effective way to prevent minor compromises from becoming systemic outages or mass data exfiltrations.
- **Unified Lifecycle and Activity Monitoring:** Implement automated tools to manage the full identity lifecycle—from provisioning to deprovisioning—while maintaining real-time visibility across hybrid cloud environments to evaluate access rights and detect anomalies before orphaned accounts or unauthorized attempts become persistent backdoors.
- **Prioritize Non-Human Identity (NHI) Governance:** Shift focus beyond human users to the larger attack surface of machine identities. Organizations should establish clear ownership and accountability for non-human identities throughout their lifecycles — including periodic access review, privilege validation, credential rotation, and retirement of unused identities. Without active governance machine identities often accumulate excessive permissions and become difficult to monitor at scale.
- **Harden Authentication Beyond Passwords:** Attackers have pivoted to targeting tokens and misconfigured trust boundaries (OAuth/OIDC). Mitigate this by deploying phishing-resistant MFA, session binding, and continuous token replay protection.
- **Govern Emergency Access and Eliminate Secret Exposure:** Reduce reliance on static credentials and accounts that bypass Zero Trust controls. Move secrets out of non-secure locations (such as environment variables) into centralized, monitored vaults with automated rotation. Emergency/break-glass accounts should require MFA, be tightly scoped, be time-bound, be checked out via approval, and alert on use.

ANECDOTES AND EXAMPLES

Here are some recent examples of this security issue causing cloud incidents:

- **(April 2026)** Vercel OAuth pivot and environment-variable exposure: Attackers abused a compromised third-party OAuth app to access a Vercel employee account, then enumerated environment variables that were not treated as secrets by default. Several teams had stored cloud provider credentials in those variables, enabling potential downstream access to customer cloud and SaaS resources [1] [2] [3].
- **(September 2025)** BRICKSTORM campaign targeting service providers: An espionage campaign targeting legal, SaaS, and BPO providers leveraged credential theft and identity abuse to gain persistent access to downstream client environments. Excessive trust in federated relationships and weak privileged-account governance amplified the impact [4] [5].
- **(2025)** MCP server default-open deployments exposed tool access: Hundreds of Model Context Protocol (MCP) servers (infrastructure for AI Agents) were found publicly accessible without authentication, exposing tool definitions, environment variables, and metadata which could be used to impersonate, escalate, and create Non-Human Identities [5][6].

CSA CBK SECURITY GUIDANCE VERSION 5.0

Domain 2: Cloud Governance
Domain 3: Risk, Audit, & Compliance
Domain 5: Identity & Access Management
Domain 6: Security Monitoring
Domain 7: Infrastructure & Networking
Domain 8: Cloud Workload Security
Domain 9: Data Security
Domain 10: Application Security
Domain 12: Related Technologies & Strategies

CSA AICM CONTROLS VERSION 1.1

AIS Application and Interface Security

AIS-01: App. & Interface Sec. Policy & Procedures
AIS-02: Application Security Baseline Requirements
AIS-03: Application Security Metrics
AIS-04: Secure Application Development Lifecycle
AIS-08: API Security

GRC Governance, Risk Mgt, and Compliance

GRC-02: Risk Management Program
GRC-04: Policy Exception Process
GRC-05: Information Security Program

IAM Identity and Access Management

IAM-01: Identity & Access Mgt Policy & Procedures
IAM-05: Least Privilege
IAM-10: Management of Privileged Access Roles
IAM-13: Strong Authentication
IAM-18: Agent Access Restriction

I&S Infrastructure Security

I&S-01: Infrastructure and Virtualization Security Policy and Procedures
I&S-03: Network Security
I&S-05: Production and Non-Production Environments
I&S-06: Segmentation and Segregation

LOG Logging and Monitoring

LOG-03: Security Monitoring and Alerting
LOG-04: Audit Logs Access and Accountability
LOG-11: Encryption Monitoring and Reporting

Reference Links

1. "The Vercel Breach: OAuth Supply Chain Attack Exposes the Hidden Risk in Platform Environment Variables"
[The Vercel Breach: OAuth Supply Chain Attack Exposes the Hidden Risk in Platform Environment Variables | Trend Micro \(US\)](#)
2. A Vercel breach exposes the OAuth gap that most security teams cannot detect, scope, or contain.
[Vercel breach exposes the OAuth gap most security teams cannot detect, scope, or contain | VentureBeat](#)
Vercel's own April 2026 security bulletin.
[Vercel April 2026 security incident | Vercel Knowledge Base](#)
3. Google Cloud / Mandiant – "Another BRICKSTORM: Stealthy Backdoor Enabling Espionage into Tech and Legal Sectors"
[Another BRICKSTORM: Stealthy Backdoor Enabling Espionage into Tech and Legal Sectors | Google Cloud Blog](#)
4. CISA/NSA/Canadian Cyber Center BRICKSTORM Malware Analysis Report (Dec 2025 – Jan 2026 update).
[BRICKSTORM Backdoor | CISA](#)
5. Astrix Security – "State of MCP Server Security 2025"
[State of MCP Server Security 2025: Research Report | Astrix](#)
6. Trend Micro – "Update on Exposed MCP Servers: The Threat Widens to the Cloud" (April 28, 2026) [Update on Exposed MCP Servers: The Threat Widens to the Cloud | Trend Micro \(US\)](#)



SECURITY ISSUE 02

AI-Enhanced Attacks

Cloud environments are particularly attractive targets for AI-enhanced attacks.

A shared responsibility model between cloud provider and cloud users creates ambiguity over security ownership: organizations routinely misconfigure controls within their scope, creating opportunities for AI to immediately identify vulnerabilities, misconfigurations, and improperly secured controls and then exploit them. The Verizon 2026 Data Breach Investigations Report identifies the exploitation of vulnerabilities as the most common initial access vector for breaches at 31%, and the time to resolve 50% of all findings was much worse than the previous year, reaching almost eight months [1]. The multi-tenant architecture of public cloud platforms means that a single compromised hypervisor layer, container runtime, or virtualization host can affect workloads belonging to multiple unrelated organizations, amplifying the potential yield of a single intrusion, and giving rapid AI attacks greater and cross-tenant impact [2].

Cloud environments concentrate an extraordinary density of credential-accessible data: identity and access management (IAM) tokens, API keys, secrets stored in environment variables, and managed database credentials are all programmatically reachable; they represent the most direct paths to lateral movement and data exfiltration at scale [3]. The Internet-exposed management plane of cloud platforms, including administrative consoles, APIs, storage endpoints, and serverless function triggers, presents a broad always-accessible attack surface, which is continuously attackable by always-available AI [4].

Frontier AI models, such as Anthropic Claude Mythos Preview, claim the ability to identify new zero-day vulnerabilities across all web browsers and operating systems, as well as to create successful sophisticated exploit code for those vulnerabilities [5]. Deepfake video and audio technology has enabled believable executive impersonation, resulting in multi-million-dollar financial fraud events [6].

Once the exclusive domain of well-resourced nation-states, sophisticated offensive capabilities are now broadly accessible to criminal organizations, hacktivists, and lone actors. The implications for cloud-dependent enterprises are profound, and demand immediate board-level attention. These threat actors actively target civilian infrastructure and use AI to scale and enhance their capabilities. A recent Microsoft report found that AI-automated phishing emails achieved a 54% click-through rate, compared with only 12% for human-crafted lures. Meanwhile, 50% of respondents at critical infrastructure organizations reported having already faced an AI-powered attack in the last year [7]. Generative AI lowers the barrier to launch complex personalized attacks at industrial scale. According to research from Syracuse University, AI-generated attacks are harder to detect than traditional methods. They can be produced at scale, making them far more dangerous than previous-generation threats [8].

TECHNICAL IMPACT

Confidentiality

- *Topology Discovery*: Network mapping is now far more accessible as AI-powered attacks can autonomously learn network topology in real time, pinpoint critical operational technologies, and dynamically evade defenses, rendering conventional perimeter security architectures obsolete [9].
- *Polymorphic and Adaptive Malware*: Traditional signature-based defenses are increasingly obsolete against AI-generated malware, which can modify its own code to evade detection. Cornell University researchers revealed in April 2024 the existence of the 'Morris II' worm, an AI-enabled self-propagating malware capable of extracting sensitive data and distributing malicious payloads across enterprise AI systems without immediate detection [11]. Darktrace notes that static signature-based defenses are fundamentally insufficient against the ever changing/morphing nature of AI-generated attacks [9].
- *Hyper-Personalized Social Engineering*: Generative AI decreases trust at scale. AI enables attackers to craft communications which are indistinguishable from those of trusted colleagues, executives, or vendors. The FBI's 2025 IC3 report logged a 37% rise in AI-assisted business email compromise (BEC) [4]. Voice cloning technology now requires only 20 to 30 seconds of audio to convincingly replicate a person's voice, while deepfake video content can be produced in under 45 minutes using freely available software [10]. These capabilities have moved from theoretical concerns to successful instances of multi-million dollar fraud.

Integrity

- *Frontier AI-Accelerated Vulnerability Discovery and Exploit Development*: These models have crossed a capability threshold that fundamentally changes the speed and accessibility of vulnerability discovery and exploit creation. Anthropic documented that Claude Mythos Preview can autonomously identify zero-day vulnerabilities in production systems, including critical memory-corruption bugs in Linux, web browsers, and operating systems, and develop working exploits without human intervention [5]. Adversaries may increasingly target agent memory, planning systems, orchestration frameworks, and tool integrations to manipulate autonomous decision-making and business workflows.

- *Runtime Kernel Memory Manipulation:* Advanced AI-enhanced payloads can target the kernel memory of virtualized and containerized cloud workloads, modifying system behavior in ways which do not leave persistent file artifacts, and bypass existing security mechanisms. These attacks subvert trust in the execution environment itself and establish long-term persistence by blinding and bypassing technical security controls, enabling threat actors to go undetected for months and years [12][13].
- *Supply Chain Compromise:* AI enables adversaries to perform convincing impersonation of trusted software packages, developer identities, and CI/CD pipeline artifacts, embedding malicious code into the cloud application supply chain with minimal risk of detection. Data supply chain integrity is at significant risk: a single poisoned training dataset can introduce vulnerabilities or backdoors into every downstream AI system and cloud service which relies on that data [9].

Availability

- *Increased Attack Scale:* AI dramatically accelerates every phase of the attack lifecycle, from reconnaissance to exploitation to lateral movement. AI enables attackers to scan for vulnerabilities, craft tailored exploits, and launch coordinated campaigns across thousands of targets simultaneously, tasks which previously required large teams of skilled operators. Phil Venables, former CISO at Google Cloud, has stated that nation-states are developing tools to automate everything from vulnerability discovery to tailored network attacks [8]. Attacks against cloud infrastructure will increase exponentially.
- *Compressed Time to Exploit:* The time-to-exploit window continues to be compressed. Attackers have been documented weaponizing newly published vulnerabilities in under 22 minutes, far outpacing traditional patch management [9]. As attacks succeed with greater frequency, cloud systems can expect to be under attack with ever greater frequency.

BUSINESS IMPACT

Operational

- *Overwhelmed Detection and Response Capabilities:* The volume and sophistication of these attacks can leave traditional monitoring, detection, and alerting systems blind and prone to false narratives, delaying response and increasing Mean Time To Detect (MTTD), Mean Time To Respond (MTTR), and dwell time [14][15].
- *Erosion of Trust in Communications:* Deepfake video, audio, and synthesized written communications blur the boundary between legitimate internal communications and adversarial content [10][16].
- *Increased Incident Complexity:* Attack chains driven or enhanced by AI can execute exploit, privilege escalation, silent persistence, lateral movement, and exfiltration in rapid succession, compressing the operational window for effective and high-assurance containment [9][17].
- *Delayed Decision Making:* Doubt and a lack of confidence in being able to see what is actually happening create uncertainty about incidents, how to respond, when recovery is successful, and whether the environment is clean [13][15].

Financial

- *Ransomware and Extortion:* AI-generated polymorphic ransomware is harder to detect and quarantine, resulting in longer dwell times, more extensive system encryption, and, consequently, higher ransom demands and recovery costs [18][19].
- *Increased Security Investment:* Organizations face compounding costs in upgrading detection technologies, retraining staff, implementing AI-aware security controls, and engaging external forensic support following incidents [20][21].
- *Direct Fraud Losses:* AI-driven social engineering, such as deepfake-enabled executive impersonation, has resulted in documented losses exceeding tens of millions of dollars per incident. Industry projections estimate AI-enabled fraud losses will reach \$40 billion USD annually by 2027 [22].

Compliance

- *Regulatory and Legal Liability:* Data breaches facilitated by AI-enhanced intrusions which circumvent established security controls may expose organizations to significant regulatory penalties under GDPR, HIPAA, and PCI DSS, along with legal liability through breach or violation of client contracts [23].
- *Speed of Regulation:* AI regulation such as the EU AI Act is outpacing organizations' ability to keep up. This makes compliance a moving target, as national and regional laws create a patchwork of requirements. This creates governance challenges as organizations struggle to apply consistent ownership, accountability, access control, and monitoring across rapidly evolving AI platforms.

Reputational

- *Customer and Partner Trust Erosion:* A successful AI-enhanced attack, for example one involving credential theft, deepfake impersonation, or data exfiltration – can severely damage customer confidence in an organization's ability to protect sensitive information [24].
- *Public Disclosure:* Incidents that require regulatory disclosure can amplify reputational damage. The public narrative around AI-enabled fraud and data theft can overshadow organizational achievements and erode stakeholder confidence [25].
- *Partner and Supply Chain Credibility:* Organizations in cloud service provider or managed service roles face particular scrutiny, as their compromise may implicate downstream customer security [26].
- *Brand Weaponization via Deepfakes:* Adversaries can use AI to create disinformation by fabricating realistic video or audio of executives making damaging statements, independent of any underlying security breach, creating reputational crises which are difficult to contain [10].

KEY TAKEAWAYS

The following recommendations reflect current best-practice guidance from NIST, Deloitte, Microsoft, Google Cloud, and Optiv, and are intended to guide immediate and near-term strategic action.

- **Establish AI Governance and Board-Level Oversight.** Google Cloud's Office of the CISO explicitly states that boards should be bilingual in AI and security to gain an advantage [27]. The Deloitte CISO Brief calls on security leaders to move from reactive controls to proactive, business-aligned defense, with clearer accountability for high-risk actions [28]. Boards should receive regular briefings on AI threat developments, and require the CISO to report on AI-specific risk metrics.
- **Adopt Zero-Trust Architecture Across Cloud Environments.** Traditional perimeter-based security is structurally inadequate for cloud environments targeted by AI-enhanced attacks. Microsoft's 2025 Digital Defense Report is unequivocal: resilience must be designed into systems, supply chains, processes, and governance [15]. Enforce continuous identity verification, least-privilege access, and micro-segmentation of cloud environments to limit the blast radius of AI-assisted intrusion [28]. Implement capabilities which address continuous verification of the runtime integrity of cloud infrastructure and workloads [13].
- **Deploy AI-Powered Defensive Capabilities Now.** Fighting AI-enhanced attacks with static, rule-based defenses is no longer viable. NIST's December 2025 Cyber AI Profile guidelines specifically call on organizations to deploy AI to enhance cybersecurity operations and thwart AI-enabled threats [29]. Organizations using security AI and automation save an average of \$2.2 million per breach compared to those without — making this investment self-financing at scale [20].
- **Secure Software Supply Chain and CI/CD Pipeline Integrity.** Implement controls across the software supply chain to detect AI-generated malicious code insertion, dependency confusion attacks, and tampered artifacts. Apply static and dynamic analysis, along with behavioral inspection, to identify AI-assisted obfuscation techniques. Integrate integrity verification into CI/CD pipelines to detect unauthorized modifications before deployment to cloud environments.

ANECDOTES AND EXAMPLES

The following recent documented findings provide concrete illustrations of AI-enhanced attack vectors and their consequences. Each offers actionable lessons for organizations seeking to improve their security posture.

- **(May 2026)** Google Threat Intelligence observed prominent cybercrime threat actors partnering to plan a mass vulnerability exploitation operation. Analysis of exploits associated with this campaign identified a zero-day vulnerability in a Python script which enabled attackers to bypass Two-Factor Authentication (2FA) on a popular open-source, web-based system administration tool [5].

- **(April 2026)** Anthropic publicly disclosed Claude Mythos Preview, stating that the model had demonstrated autonomous vulnerability discovery across every major operating system and web browser, as well as the creation of zero-day exploits for those vulnerabilities [5].
- **(March 2026)** ESET Research published a report on EDR Killers, which are designed to target endpoint detection and response (EDR) products to blind, bypass, and/or disable them. They assert strong confidence and share research evidence that AI was used in the creation of some of the 90 variations of EDR Killers actively in use in the wild [30].
- **(January 2026)** Check Point Research disclosed, with high confidence, a cloud-native Linux malware framework named VoidLink that was created using AI. VoidLink features a sophisticated, modular command-and-control framework written in Zig, with cloud environment detection, a plugin ecosystem of over 30 modules, and multiple rootkit capabilities spanning userland rootkits, Loadable Kernel Modules, and eBPF [12].

CSA CBK SECURITY GUIDANCE VERSION 5.0

Domain 2: Cloud Governance and Strategies
Domain 3: Risk, Audit, and Compliance
Domain 4: Organization Management
Domain 5: Identity and Access Management
Domain 6: Security Monitoring
Domain 7: Infrastructure & Networking
Domain 8: Cloud Workload Security
Domain 9: Data Security
Domain 10: Application Security
Domain 11: Incident Response & Resilience
Domain 12: Related Technologies & Strategies

CSA AICM CONTROLS VERSION 1.1

GRC Governance, Risk Mgt, and Compliance

GRC-01: Governance Program Policy and Procedures

GRC-02: Risk Management Program

GRC-03: Organizational Policy Review

GRC-05: Information Security Program

IAM Identity and Access Management

IAM-01: Identity and Access Management Policy and Procedure

IAM-02: Credentials Management Policy and Procedures

IAM-05: Least Privilege

LOG Logging and Monitoring

LOG-01: Logging and Monitoring Policy and Procedures

LOG-02: Audit Logs Protection

LOG-03: Security Monitoring and Alerting

LOG-05: Audit Logs Monitoring and Response

SEF Security Incident Management, E-Discovery & Cloud Forensics

SEF-01: Security Incident Management Policy and Procedures

SEF-02: Service Management Policy and Procedures

SEF-03: Incident Response Plans

SEF-04: Incident Response Testing

STA Supply Chain Management, Transparency and Accountability

STA-01: Supply Chain Risk Management Policies and Procedures

STA-04: SSRM Guidance

STA-07: SSRM Control Implementation

TVM Threat & Vulnerability Management

TVM-01: Threat and Vulnerability Management Policy and Procedures

TVM-02: Malware and Malicious Instructions Protection Policy and Procedures

TVM-03: Vulnerability Identification

TVM-08: Vulnerability Remediation Schedule

Reference Links

1. Verizon 2026 Data Breach Investigations Report
www.verizon.com/business/resources/reports/2026-dbir-data-breach-investigations-report.pdf
2. AI-Enabled System for Efficient and Effective Cyber Incident Detection and Response in Cloud Environments
arxiv.org/pdf/2404.05602
3. AI Cybersecurity Statistics in 2025: Comprehensive Data on Threats, Detection, and Defense
www.totalassure.com/blog/ai-cybersecurity-stats-2025
4. AI Cyber Attack Statistics 2025 -- Full Report
deepstrike.io/blog/ai-cyber-attack-statistics-2025
5. Assessing Claude Mythos Preview's Cybersecurity Capabilities
red.anthropic.com/2026/mythos-preview
6. FBI Warns of Increasing Threat of Cyber Criminals Utilizing Artificial Intelligence
www.fbi.gov/contact-us/field-offices/sanfrancisco/news/fbi-warns-of-increasing-threat-of-cyber-criminals-utilizing-artificial-intelligence
7. AI is about to supercharge cyberattacks
www.axios.com/2025/10/25/ai-is-about-to-supercharge-cyberattacks

8. Syracuse University iSchool. AI in Cybersecurity: How AI is Changing Threat Defense ischool.syracuse.edu/ai-in-cybersecurity/
9. AI and Cybersecurity: Predictions for 2025 www.darktrace.com/blog/ai-and-cybersecurity-predictions-for-2025 Verizon 2026 Data Breach Investigations Report www.verizon.com/business/resources/reports/2026-dbir-data-breach-investigations-report.pdf
10. AI Cyber Threat Statistics: The 2025 Landscape thenetworkinstallers.com/blog/ai-cyber-threat-statistics/
11. AI Cyber Attack Statistics 2025 tech-adv.com/blog/ai-cyber-attack-statistics/
12. VoidLink: Evidence That the Era of Advanced AI-Generated Malware Has Begun research.checkpoint.com/2026/voidlink-early-ai-generated-malware-framework
13. Why the Market Needs a Better Model for Trust in Live Systems www.invary.com/articles/better-model-for-trust-in-live-systems
14. Microsoft 2025 Digital Defense Report industrialcyber.co/reports/microsoft-2025-digital-defense-report
15. The 11 runtime attacks breaking AI security -- and how CISOs are stopping them venturebeat.com/security/ciso-inference-security-platforms-11-runtime-attacks-2026
16. This Happens More Frequently Than People Realize - Arup Chief on \$25M Deepfake Crime www.weforum.org/stories/2025/02/deepfake-ai-cybercrime-arup/
17. Disrupting the First Reported AI-Orchestrated Cyber Espionage Campaign www.anthropic.com/news/disrupting-AI-espionage
18. Cyberattack Costs in 2025: Statistics, Trends, and Real Examples www.expressvpn.com/blog/the-true-cost-of-cyber-attacks-in-2024-and-beyond/
19. Real-Life Examples of How AI Was Used to Breach Businesses oxen.tech/blog/real-life-examples-of-how-ai-was-used-to-breach-businesses-omaha-ne/
20. Massive AI Cyberattacks Cost SMBs \$10.5T in 2025 www.networkdr.com/cybersecurity/ai-cyberattacks-smb-losses-2025-protect/
21. AI for CISOs: Cutting Cybersecurity Costs and Mitigating Risks in 2026 www.trustcloud.ai/ai/how-cisos-can-use-ai-to-cut-security-costs-and-risks/
22. Generative AI is expected to magnify the risk of deepfakes and other fraud in banking www.deloitte.com/us/en/insights/industry/financial-services/deepfake-banking-fraud-risk-on-the-rise.html
23. When Artificial Intelligence Becomes the Hacker: Legal Risks and Compliance Strategies for Autonomous Cyber Threats www.shumaker.com/insight/when-artificial-intelligence-becomes-the-hacker-legal-risks-and-compliance-strategies-for-autonomous-cyber-threats/
24. The Hidden Costs of a Cyberattack: The Impact on Reputation cyesec.com/blog/hidden-costs-cyberattack-impact-reputation
25. AI Risk Disclosures in the S&P; 500: Reputation, Cybersecurity, and Regulation corpgov.law.harvard.edu/2025/10/15/ai-risk-disclosures-in-the-sp-500-reputation-cybersecurity-and-regulation/
26. Six Supply Chain Attack Groups to Watch Out for in 2026 www.group-ib.com/blog/supply-chain-attack-groups-2026/
27. Cloud CISO Perspectives: 2025 in Review cloud.google.com/blog/products/identity-security/cloud-ciso-perspectives-2025-in-review

28. The CISO Brief: AI Threat Landscape & Security Controls
www.deloitte.com/us/en/services/consulting/articles/ai-threat-landscape-security-controls.html
29. Draft NIST Guidelines Rethink Cybersecurity for the AI Era
www.nist.gov/news-events/news/2025/12/draft-nist-guidelines-rethink-cybersecurity-ai-era
30. EDR killers explained: Beyond the drivers
www.welivesecurity.com/en/eset-research/edr-killers-explained-beyond-the-drivers

SECURITY ISSUE 03

Insecure Third-Party Resources



Software supply chain exposure is now a dominant cloud security issue, including multiple NPM attacks [1][3][4]. One weak vendor can lead to compromise of multiple downstream organizations. The term “third-party resource” has broadened its meaning well beyond externally authored code and open-source libraries. It now encompasses SaaS dependencies, managed APIs, CI/CD pipelines, container-based images, and AI-generated components. Each of these elements is essential to delivering a cloud service to customers. Managing this Cybersecurity Supply Chain Risk Management (C-SCRM) exposure is now a baseline contractual and regulatory expectation, having moved from a compliance line item to a standing board-level responsibility.

A cloud product is the sum of all its components, which means a compromise might originate in any of them. A single transitive dependency, a tampered build step, or a hijacked maintainer account several tiers upstream, can all affect third-party resources and compromise the first-party resource that depends on them. Adversaries exploit this asymmetry deliberately: they need not breach the hardened primary target, only the weakest link in its dependency graph. That link is frequently from a small, under-resourced supplier whose output is nonetheless implicitly trusted and executed across many downstream estates.

AI models, orchestration layers, managed APIs, and generated code should be governed as first-class supply-chain dependencies, subject to the same inventory, provenance, and risk-validation controls applied to traditional software components. NIST SP 800-161 emphasizes integrating cybersecurity supply chain risk management into organizational risk activities through policies, plans, and product-level assessments, which aligns well with treating each external dependency as a traceable and continuously monitored trust boundary. In practice this means requiring a complete SBOM, artifact signing, reproducible or verifiable builds, and CI/CD policy gates that block unsigned or unapproved components before deployment. For AI-dependent components organizations should also validate model origin, training-data lineage where available, update mechanisms, and prompt or agent behavior changes as part of the same assurance process.

TECHNICAL IMPACT

Confidentiality

- *Data Disclosure:* Compromised third-party components or access paths can enable unauthorized access to sensitive cloud data including credentials, API keys, customer records, and secrets, thereby compromising confidentiality. Modern supply chain malware routinely sweeps cloud credentials, Kubernetes configurations, SSH keys, and tokens directly from build and runtime environments.

Integrity

- *Unauthorized Modification and Data Destruction:* Malicious or poorly governed upstream changes can introduce code that tampers with, corrupts, or destroys data and artifacts. A trojanized package or build step executes with the host application's trust, enabling attackers to alter deployment artifacts, inject backdoors, or wipe systems.

Availability

- *Service Disruption:* Unpatched or late-remediated vulnerabilities in supply chain components can be exploited to disrupt or take down production systems. Self-propagating supply chain worms and destructive payloads can cause widespread outages across dependent services. This includes attacks that wipe developer or host environments upon detecting token revocation.

BUSINESS IMPACT

Operational

- *Production System Outage:* Unpatched or late-remediated vulnerabilities in supply chain components can be exploited to disrupt or take down production systems.
- *Emergency Remediation:* A confirmed dependency compromise forces broad secret rotation, environment rebuilds, and pipeline re-hardening, diverting teams from planned work.

Financial

- *Non-compliance and Fines:* Regulatory and contractual liability generally do not transfer to the supplier, even though they can be accountable; the customer remains accountable for fines, damages, and remediation costs arising from third-party failures.
- *Incident and Recovery Costs:* Forensic investigation, credential rotation, and cloud resource abuse following a compromise can generate substantial unplanned costs.

Compliance

- *Regulatory Violations:* A third-party compromise that exposes regulated data can breach data-protection and industry-specific mandates such as GDPR, CCPA, and PCI DSS, with accountability remaining the client's liability.
- *Audit Findings:* The absence of a maintained software inventory (SBOM/SaaSOM) or a documented supplier assessment process commonly results in failed assessments and control gaps.

Reputational

- *Company Confidence*: A publicly disclosed breach traced to a supply chain dependency undermines customer trust in the organization's ability to safeguard sensitive information, regardless of where the fault originated.
- *Public Scrutiny and Amplification*: When a supply chain incident becomes a viral or trending story, the reputational damage is amplified far beyond its technical scope. Social media and news cycles attach the organization's name to a widely circulated narrative — often before the facts are established — accelerating loss of customer and investor confidence and drawing regulator, partner, and press attention to an incident that originated with a third party.

KEY TAKEAWAYS

- **Make informed sourcing decisions**: No software can be fully secured, least of all code or products the organization did not author. Favor third-party resources that are actively and officially supported, and evaluate suppliers on relevant compliance certifications, transparency around their security programs, the presence of a bug bounty or coordinated disclosure process, and a demonstrated record of timely remediation.
- **Establish visibility into the estate**: Use Software Composition Analysis (SCA) to identify third-party components and produce a Software Bill of Materials (SBOM) and, for hosted dependencies, a SaaS Bill of Materials (SaaS SBOM). Some practitioners might consider an AI Bill of Materials (AIBOM), but there currently is no standard.
- **Maintain inventories as living artifacts**: Continuously track the third parties in your cloud supply chain. The organization should not first learn that it depends on a vulnerable component when a victim list is published. Coverage must extend to open source, SaaS products, cloud providers, managed services, and every active integration. It must also identify extensible platforms, plug-in frameworks, marketplaces, and dynamic integrations that can introduce new dependencies after deployment. These paths require approval, monitoring, and inventory updates whenever additional components or services are connected.
- **Subject third-party resources to periodic review**: Apply both automated and manual review. Where the process surfaces a component which is no longer needed, or an outdated version carrying known security issues, remediate it through the appropriate channel. This review must also cover standing access grants to critical assets such as code repositories, infrastructure, and high-impact applications.
- **Extend security expectations upstream**: Work with suppliers to ensure they have the training and tooling to perform automated application security testing on their products before they enter your environment. AI-assisted SAST and SCA tooling can accelerate review of third-party components, but treat AI-generated and AI-assisted code as another third-party input subject to the same scrutiny.

ANECDOTES AND EXAMPLES

Recent incidents resulting from insecure third-party resources include:

- **(August 2025)** Malicious versions of the Nx build system, a package with millions of weekly downloads, were published to npm after attackers exploited a vulnerable `pull_request_target` workflow to obtain an npm publishing token. The malware harvested GitHub and npm tokens, SSH keys, cloud credentials, and cryptocurrency wallets. It was also the first documented malware to weaponize locally installed AI command-line assistants. It invoked the assistants with permission-bypassing flags such as `--dangerously-skip-permissions` and `--yolo` to automate reconnaissance and secret discovery. A second wave then used the leaked tokens to make private repositories public, ultimately exposing thousands of repositories and thousands of valid credentials [1].
- **(March 2026)** According to Trend Micro, a financially motivated threat actor known as TeamPCP executed a multi-stage cascading supply chain attack that ultimately compromised LiteLLM, a Python AI proxy library with approximately 3.4 million daily downloads on PyPI. The attackers began by exploiting a misconfigured GitHub Actions workflow in Aqua Security's Trivy vulnerability scanner to steal a publish token, which they then used to inject malicious code into LiteLLM's CI/CD pipeline and publish two trojanized versions (1.82.7 and 1.82.8) before PyPI quarantined them roughly three hours later. The embedded malware swept across more than 50 categories of secrets, including cloud credentials, Kubernetes configs, SSH keys, LLM API keys, and cryptocurrency wallets, and installed a persistent backdoor which polls for remote code execution commands. Downstream projects, including DSPy, MLflow, CrewAI, and OpenHands, were all affected, and Wiz reported LiteLLM was present in 36% of cloud environments analyzed [2].
- **(March 2026)** According to Google Threat Intelligence, a North Korea-nexus threat actor known as UNC1069 compromised the widely used axios npm package, which sees over 100 million weekly downloads, by injecting a malicious dependency called plain-crypto-js into versions 1.14.1 and 0.30.4. The malicious package silently deployed a cross-platform backdoor called WAVESHAPER.V2 across Windows, macOS, and Linux systems, enabling attackers to execute commands, enumerate file systems, and inject arbitrary payloads into compromised developer machines and build environments [3].
- **(May 2026)** According to Wiz, the threat actor TeamPCP launched a coordinated supply chain attack on May 11, 2026, compromising over 100 npm package versions across high-profile namespaces, including @tanstack, @mistralai, and @uiopath, with @tanstack/react-router alone receiving approximately 12 million weekly downloads. The attackers exploited a chain of GitHub Actions vulnerabilities, using a forked repository to poison the Actions cache and extract OIDC tokens directly from the GitHub runner process memory, allowing them to publish malicious packages without ever stealing npm credentials. The malware functioned as a self-propagating worm that stole CI/CD tokens, cloud credentials, and Kubernetes secrets while spreading to additional packages to which victims had write access to, exfiltrating data across three channels including a typosquatted domain and the decentralized Session messenger network. Perhaps most notably, the payload included a persistent monitoring daemon that, upon detecting token revocation, attempted to wipe the victim's home directory entirely [4].

CSA CBK SECURITY GUIDANCE VERSION 5.0

Domain 1: Cloud Computing Concepts and Architectures

Domain 2: Cloud Governance

Domain 3: Risk, Audit & Compliance

Domain 5: Identity & Access Management

Domain 7: Infrastructure & Networking

Domain 10: Application Security

Domain 11: Incident Response & Resilience

CSA AICM CONTROLS VERSION 1.1

BCR Business Continuity Mgt & Op. Resilience

BCR-01: Business Continuity Mgt Policy & Procedures

BCR-02: Risk Assessment and Impact Analysis

BCR-03: Business Continuity Strategy

CCC Change Control and Configuration Mgt

CCC-04: Unauthorized Change Protection

CCC-05: Change Agreements

DCS Datacenter Security

DCS-05: Assets Classification

DCS-06: Assets Cataloging and Tracking

DCS-07: Controlled Physical Access Points

DSP Data Security & Privacy Lifecycle Mgt

DSP-03: Data Inventory

DSP-05: Data Flow Documentation

DSP-06: Data Ownership and Stewardship

DSP-08: Data Privacy by Design and Default

DSP-10: Sensitive Data Transfer

DSP-16: Data Retention and Deletion

IAM Identity and Access Management

IAM-05: Least Privilege

IAM-10: Management of Privileged Access Roles

IAM-11: CSCs Approval for Agreed Privileged Access Roles

IAM-14: Strong Authentication

IAM-16: Authorization Mechanisms

IPY Interoperability & Portability

IPY-01: Interoperability and Portability Policy and Procedures

IPY-02: Application Interface Availability

IPY-03: Secure Interoperability and Portability Management

IPY-04: Data Portability Contractual Obligations

SEF Security Incident Management, E-Discovery, & Cloud Forensics

SEF-01: Security Incident Management Policy and Procedures

SEF-03: Incident Response Plans

SEF-07: Security Breach Notification

STA Supply Chain Management, Transparency and Accountability

STA-08 Supply Chain Inventory

STA-09 Supply Chain Risk Management

STA-16 Service Bill of Material (BOM)

STA-12 Supply Chain Compliance Assessment

STA-13 Supply Chain Service Agreement Compliance

Reference Links

1. StepSecurity. "s1ngularity: Popular Nx Build System Package Compromised with Data-Stealing Malware" (August 2025)
www.stepsecurity.io/blog/supply-chain-security-alert-popular-nx-build-system-package-compromised-with-data-stealing-malware
2. Trend Micro. "Your AI Gateway Was a Backdoor: Inside the LiteLLM Supply Chain Compromise." March 2026 -
www.trendmicro.com/en_us/research/26/c/inside-litellm-supply-chain-compromise.html
3. Google. "North Korea-Nexus Threat Actor Compromises Widely Used Axios NPM Package in Supply Chain Attack." March 2026
cloud.google.com/blog/topics/threat-intelligence/north-korea-threat-actor-targets-axios-npm-package
4. Wiz. "Mini Shai-Hulud Strikes Again: TanStack + more npm Packages Compromised." May 2026
www.wiz.io/blog/mini-shai-hulud-strikes-again-tanstack-more-npm-packages-compromised

Insecure Interfaces and APIs

Cloud Service Providers (CSPs), enterprise vendors, and internal developers expose machine-to-machine Application Programming Interfaces (APIs) and human-facing User Interfaces (UIs) that serve as the primary control plane for cloud services. These interfaces govern how users, applications, and increasingly autonomous AI agents interact with cloud resources. As organizations adopt cloud-native architectures, microservices, and API-driven integrations, the number and complexity of APIs have grown dramatically. Two-thirds of organizations reported API growth exceeding 50% in the past year [1], and APIs now account for the majority of internet traffic. This expansion has made APIs the primary attack surface of digital business. This is not because of novel zero-day exploits but because of compounding failures in identity, exposure, and abuse detection controls. As detailed under Security Issue 01, API security is now as much an identity and access management problem as an application security problem. Over half of analyzed API breaches in 2025 traced back to broken authentication and over-permissioned Non-Human Identities, not application-layer exploitation [2].

APIs and UIs remain vulnerable due to persistent flaws in access control, visibility, and identity management. The converging risks are best categorized by the OWASP API Security Top 10 [3] and the OWASP Top 10 for LLM Applications [4], driven by three main factors:

- **Core Authorization & Authentication Flaws:** Broken authentication accounted for 52% of analyzed API breaches. Additionally, unsafe API consumption accounted for 27% of these breaches [2].
- **The Machine Identity Crisis:** Non-Human Identities, such as API keys and OAuth tokens, represent a significant risk. Over 30,000 publicly accessible developer workspaces were found leaking API keys, access tokens, and refresh tokens [5].
- **Visibility Gaps:** Security teams struggle to monitor undocumented endpoints. In fact, organizations have 33% more public-facing API endpoints than they realize, commonly referred to as shadow APIs [6].

AI-driven cloud services have drastically expanded the API attack surface, particularly through the Model Context Protocol (MCP). MCP enables AI agents to dynamically interact with external systems using delegated user permissions and chained tool calls [5]. In a traditional API call, authorization is checked per-request against a known identity. MCP works differently: agents inherit broad permissions at connection time, and the protocol does not carry user-level authorization context to each downstream tool. This enables a 'confused deputy' condition. This non-deterministic behavior significantly amplifies the impact of a single exploit: in 2025, MCP-related flaws accounted for 315 vulnerabilities (14.4% of all AI-related vulnerabilities), surging 270% in a single quarter [2]. Driven by over-permissioned tools and inadequate authentication, compromising an MCP server goes beyond simple data theft: it grants attackers control over autonomous workflows, effectively weaponizing the API layer as a command-and-control surface.

Driven by rapid deployment cycles and the explosion of Non-Human Identities, insecure APIs remain a major cloud threat as configuration drift continually outpaces security review. Furthermore, as AI agents consume these vulnerable interfaces at machine speed without human oversight, the impact of long-standing weaknesses expands exponentially, transforming traditional data exposure risks into pathways for autonomous, unauthorized actions.

TECHNICAL IMPACT

Confidentiality

- *Unauthorized System Access:* Broken authentication or authorization controls can allow attackers to access backend systems, escalate privileges, or impersonate legitimate users and services. In AI-enabled environments, compromised APIs can grant control over model inference, remote tool execution, or agent workflows.
- *Data Disclosure:* Sensitive data can be exposed through overly permissive API responses, misconfigured query parameters, unsecured AI inference endpoints, or unsafe consumption of third-party APIs. Mass data harvesting, in which millions of records are scraped via unprotected endpoints, remains a persistent risk.

Integrity

- *Unauthorized Data Modification:* APIs which fail to enforce method-level or object-level authorization allow attackers to invoke write or delete operations, corrupting records, altering configurations, or destroying critical data.
- *Agentic Workflow Manipulation:* Compromised API calls in MCP-connected environments can redirect agent behavior, inject false tool results that alter data or decisions across connected systems, and be hard to trace.

Availability

- *Denial of Service via Unthrottled APIs:* APIs without rate limiting, throttling, or payload size restrictions can be abused to exhaust compute, memory, or downstream service quotas, resulting in degraded performance or complete service outages for legitimate users.
- *Cascading Failures in Agentic Pipelines:* An MCP server that returns unauthenticated or malformed tool responses can cause downstream AI agents to take unintended actions without a traceable root cause.

BUSINESS IMPACT

Operational

- *System Outage:* APIs without proper rate limiting or throttling can be targeted by denial-of-service attacks or resource exhaustion, resulting in complete or partial disruption of cloud services and business operations.
- *Autonomous Action Risk:* In agentic AI environments a compromised MCP server or an over-permissioned interface can enable AI agents to execute unauthorized workflows, modify data, or interact with external systems without human approval.

Financial

- *Lost Revenue:* Financial losses can occur due to service disruptions, service restoration, customer dissatisfaction, or legal action.
- *Non-compliance and Fines:* Failure to comply with vulnerability management regulatory requirements may result in penalties.

Compliance

- *Data Protection Regulatory Violations:* Insecure API practices that lead to unauthorized data access or exposure may violate GDPR and HIPAA, triggering mandatory breach notifications and enforcement action.
- *AI Regulation Non-Compliance:* Insecure MCP interfaces or AI inference endpoints that expose model outputs or training data may violate emerging AI-specific regulations and governance frameworks, including the EU AI Act.

Reputational

- *Company Reputation:* Damage to the cloud service organization's public image and brand value. Publicly disclosed API breaches, such as those involving mass data harvesting and exposed credentials, can damage an organization's public image and erode customer trust.
- *Customer Reputation:* Clients relying on weakly secured API-based cloud services may experience data breaches and service interruptions, which can negatively impact reputations and customer relationships.

KEY TAKEAWAYS

- **Secure authentication, authorization, and credential lifecycles across all API interfaces:** In addition to authentication and fine-grained authorization, enforce short-lived, automatically rotated credentials rather than static bearer tokens or long-lived API keys. Any human-facing interface must have attribute-based access control, and machine-to-machine interfaces must enforce least-privilege scoping, as defined by the best practices discussed in Security Issue 01: Inadequate Identity and Access Management. Implement proper guardrails, such as rate limiting and throttling.
- **Establish continuous API discovery and inventory:** Organizations cannot secure APIs they do not know exist. Deploy automated API discovery to identify shadow APIs, zombie APIs,

and undocumented endpoints across cloud environments. Maintain a current authoritative API inventory that includes both human-facing and machine-to-machine interfaces, and decommission deprecated endpoints that are no longer actively maintained. Gate every API and interface change with pre-deployment DAST, fuzzing, and schema-conformance testing in CI/CD, and scan production continuously for drift and newly disclosed vulnerabilities.

- **Treat AI inference endpoints and agentic tool-calling interfaces as first-class API security surfaces:** Apply authentication, authorization, input validation, rate limiting, and monitoring to AI model endpoints, MCP servers, and orchestration APIs with the same rigor as any production service. Restrict agent permissions using least-privilege principles, enforce runtime boundaries on tool execution, and monitor for anomalous chained tool calls that could indicate prompt injection or agent hijacking.
- **Adopt the OWASP API Security Top 10 and the OWASP Top 10 for LLM Applications as complementary frameworks:** Use these together to assess and address the full spectrum of API security risks, from traditional broken authentication and authorization flaws to AI-specific vulnerabilities such as prompt injection, excessive agency, and insecure plugin design.

ANECDOTES AND EXAMPLES

Recent incidents resulting from insecure interfaces and APIs include:

- **(April 2025) Legacy Stripe API “Zombie” Exploitation:** Security researchers identified a web skimming campaign that exploited the deprecated Stripe “v1/sources” endpoint to validate stolen credit card data across 49 compromised merchants. Although superseded by the PaymentMethods API in May 2024, the endpoint remained functional and unmonitored. Attackers used malicious JavaScript to capture customer data, then used this “zombie API” to verify cards before exfiltrating them. This incident underscores the danger of legacy endpoints which fall outside active governance, and illustrates why organizations must decommission — not merely deprecate — old interfaces [7][8].
- **(August 2025) Intel API Authentication Failures:** Dubbed “Intel Outside,” a series of vulnerabilities exposed 270,000 employee records via unauthenticated API endpoints. Attackers could bypass authentication by manipulating client-side JavaScript and retrieve massive datasets due to a complete lack of server-side authorization and rate limiting. The breach demonstrates that client-side controls provide no meaningful protection, and underscores the necessity of enforcing strict data-return limits and server-side verification for all internal APIs [9][10][11].
- **(October 2025) 700Credit Third-Party API Breach:** 700Credit, the largest credit report and identity verification provider for the automotive industry in North America, suffered a breach exposing the personal data of 5.8 million individuals — including names, addresses, dates of birth, and Social Security numbers. The breach originated when an unnamed integration partner’s systems were compromised in July 2025; the partner failed to notify 700Credit. Attackers extracted API tokens and communication logs from the partner’s environment, then used those credentials to authenticate against 700Credit’s API and issue high-volume, legitimate-looking requests against consumer records. This sustained

“velocity attack” lasted approximately two weeks. The API had no controls to verify whether the requesting partner was authorized to access specific consumer records at that volume. The incident demonstrates how unsafe consumption of third-party APIs can expose millions of records when partner credential governance, API request validation, or behavioral monitoring is insufficient [12][13][14].

- **(April 2026) MCP Architectural Vulnerability:** Researchers disclosed a critical design flaw in the Model Context Protocol’s (MCP) STDIO transport interface, affecting over 7,000 servers and 150 million downloads. Unlike a typical bug, this weakness is inherent to the protocol’s design, enabling Remote Code Execution (RCE) through the communication channel between AI agents and servers (CVE-2026-22252, CVE-2026-22688). Combined with previous injection flaws in reference implementations, these vulnerabilities highlight the systemic risk of deploying standardized AI agent protocols without a rigorous security review of their underlying transport mechanisms [15][16][17].

CSA CBK SECURITY GUIDANCE VERSION 5.0

Domain 3: Risk, Audit, & Compliance

Domain 4: Organization Management

Domain 5: Identity & Access Management

Domain 6: Security Monitoring

Domain 7: Infrastructure & Networking

Domain 8: Cloud Workload Security

Domain 9: Data Security

Domain 10: Application Security

Domain 11: Incident Response & Resilience

Domain 12: Related Technologies & Strategies

CSA AICM CONTROLS VERSION 1.1

AIS Application & Interface Security

AIS-01: App. & Interface Sec. Policy & Procedures

AIS-04: Secure Application Development Lifecycle

AIS-06: Automated Secure Application Deployment

AIS-08: API Security

AIS-11: Agents Security Boundaries

CEK Cryptography, Encryption & Key Management

CEK-03: Data Encryption

CEK-04: Encryption Algorithm

CEK-12: Key Rotation

CCC Change Control and Configuration Mgt

CCC-01: Change Management Policy and Procedures

CCC-02: Quality Testing

CCC-07: Detection of Baseline Deviation

DSP Data Security and Privacy Lifecycle Management

DSP-01: Security and Privacy Policy and Procedures

DSP-03: Data Inventory

DSP-04: Data Classification

DSP-05: Data Flow Documentation

IAM IAM Identity & Access Management

IAM-05: Least Privilege
IAM-08: Access Review
IAM-13: Strong Authentication
IAM-16: Authorization Mechanisms
IAM-19: Agent Access Restriction

I&S I&S Infrastructure Security

I&S-03: Network Security
I&S-04: OS Hardening and Base Controls
I&S-09: Network Defense

LOG LOG Logging and Monitoring

LOG-03: Security Monitoring and Alerting
LOG-05: Audit Logs Monitoring and Response

Reference Links

1. Salt Security. "H1 2026 State of AI and API Security: Navigating the Agentic Era." April 2026 - salt.security/blog/the-era-of-agentic-security-is-here-key-findings-from-the-1h-2026-state-of-ai-and-api-security-report
2. Wallarm. "2026 API ThreatStats Report." February 2026 - lab.wallarm.com/inside-modern-api-attacks-what-we-learn-from-the-2026-api-threatstats-report
3. OWASP. "API Security Top 10." 2023. owasp.org/www-project-api-security/
4. OWASP. "Top 10 for Large Language Model Applications." owasp.org/www-project-top-10-for-large-language-model-applications/
5. CloudSEK. "Postman Data Leaks: The Hidden Risks Lurking in Your Workspaces." December 2024. www.cloudsek.com/blog/postman-data-leaks-the-hidden-risks-lurking-in-your-workspaces
6. Cloudflare. "Application Security Report: 2024 Update." June 2024. Available at: blog.cloudflare.com/application-security-report-2024-update/
7. The Hacker News. "Legacy Stripe API Exploited to Validate Stolen Payment Cards in Web Skimmer Campaign." April 2025. thehackernews.com/2025/04/legacy-stripe-api-exploited-to-validate.html
8. Jscrambler Research (via Hackread). Hackers Exploit Stripe API for Web Skimming Card Theft on Online
9. Eaton Works. "Intel Outside: Hacking Every Intel Employee and Various Internal Websites." August 2025. eaton-works.com/2025/08/18/intel-outside-hack/
10. Tom's Hardware. "Researcher Downloaded the Data of All 270,000 Intel Employees from an Internal Business Card Website." August 2025. www.tomshardware.com/tech-industry/cyber-security/researcher-downloaded-the-data-of-all-270-000-intel-employees-from-an-internal-business-card-website-massive-data-breach-dubbed-intel-outside-didnt-qualify-for-bug-bounty
11. Cybernews. "Hacker Exposes 270K Intel Employees' Data, Gets Automated Thank You." August 2025. cybernews.com/security/hacker-uncovers-intel-system-flaws/
12. SecurityWeek. "700Credit Data Breach Impacts 5.8 Million Individuals." December 2025. www.securityweek.com/700credit-data-breach-impacts-5-8-million-individuals/
13. Outpost24 Threat Intelligence. "700Credit Data Breach: What Organizations Need to Know." January 2026. outpost24.com/blog/700credit-data-breach/

14. Paubox. "Third-party API breach at 700Credit exposes data of 5.6 million people." January 2026.
www.paubox.com/blog/third-party-api-breach-at-700credit-exposes-data-of-5.6-million-people
15. The Hacker News. "Anthropic MCP Design Vulnerability Enables RCE." April 2026.
thehackernews.com/2026/04/anthropic-mcp-design-vulnerability.html
16. Trend Micro. "Why a Classic MCP Server Vulnerability Can Undermine Your Entire AI Agent." June 2025.
www.trendmicro.com/en_us/research/25/f/why-a-classic-mcp-server-vulnerability-can-undermine-your-entire-ai-agent.html
17. Palo Alto Unit 42. "New Prompt Injection Attack Vectors Through MCP Sampling." December 2025.
unit42.paloaltonetworks.com/model-context-protocol-attack-vectors/

Misconfiguration and Inadequate Change Control



Misconfiguration is the incorrect configuration of cloud and AI systems, often caused by inadequate change control. It produces unintended exposure of data that organizations mostly discover after the fact, not before. The most common causes are identities with too many permissions and misconfigured storage. Inadequate logging means the exposure often goes undetected until an incident forces a review. The Cloud Security Alliance identifies misconfiguration as one of the most significant cloud security threats — typically caused by human error, lack of knowledge, or failure to follow security best practices [1]. In AI-enabled environments the same errors reach assets that cloud security was not originally built to protect.

Without change control, misconfigurations introduced during updates or pipeline modifications remain in place indefinitely. Unreviewed changes to prompts and infrastructure accumulate quietly. Nothing flags them until something breaks. Revised prompts and dataset refreshes frequently bypass formal review, because they are not always treated as changes. NIST AI RMF 1.0 notes that AI systems may rely on data which changes over time in ways that affect system functionality and trustworthiness [2]. Configuration drift follows. Insecure settings reach production without independent review, and no one is accountable for catching them.

Misconfigurations occur across both the cloud and AI lifecycles. They affect identity and access management, storage, networking, logging, compute, and platform services in the cloud. They extend to model-hosting environments, inference APIs, orchestration frameworks, Model Context Protocol (MCP) servers, vector databases, RAG pipelines, agent-tool permissions, monitoring systems, and AI-related access-control policies.

Common examples include

- Publicly accessible endpoints
- Unsecured model artifacts
- Misconfigured vector databases
- Improper secret management
- Exposed API keys or credentials
- Over-permissioned identities or agents
- Disabled validation controls

Publicly exposed cloud and AI services are routinely discovered through automated Internet scanning. Attackers do not need to target an organization specifically. Misconfigured interfaces advertise themselves. These exposures are predominantly the result of human error rather than software flaws. Google Cloud's H1 2025 Threat Horizons Report found that misconfigurations accounted for 29.4% of observed initial access vectors in cloud incidents, second only to weak or absent credentials [3]. OWASP LLM Top 10 2025 (LLM08) identifies RAG infrastructure as a distinct attack surface. Standard cloud security controls cover permissions, network exposure, and logging, but embedding integrity, retrieval manipulation, and vector database access patterns fall outside those areas [4].

Misconfigurations in underlying cloud services spread into AI pipelines. AI systems run on those platforms and process sensitive data, inference results, and high-value intellectual property. Exposure does not stop at the cloud layer. As Wiz Research notes, a single misconfigured AI service can expose connected systems and pipelines which were never directly targeted [5].

TECHNICAL IMPACT

Confidentiality

- *Exposure of Sensitive Data:* The most frequent cause is not software issues. It is a default setting that was never changed, or permissions which were never properly set. A single exposed API key gives an attacker valid credentials and access to service endpoints. From there, lateral movement through connected systems looks like normal API traffic. The usual detection controls rarely catch it.
- *Disclosure of Credentials and Configuration Information:* Exposed environment variables and infrastructure metadata map out the internal environment for attackers. They study before they move. This information shows them where high-value targets are, and how to reach them quietly.
- *Infrastructure and Environment Disclosure:* Exposed deployment details and cloud resource configurations reveal how systems are built and managed. Attackers use them to find where change control is weak. Systems with unreviewed modifications are the first targets.

Integrity

- *Unauthorized Modification or Corruption of Data:* Most of the time, the problem isn't malicious intent. It's a change that reached production without proper review, testing, or approval. Affected assets include datasets, model artifacts, configuration settings, and operational data.
- *Configuration Drift and Security Control Erosion:* Security controls weaken gradually, as unreviewed changes accumulate. Systems drift away from approved configurations. Often

no one notices until a control fails or an incident exposes a problem.

- *Unapproved Configuration Changes:* Changes made directly to production without approval violate change-control policy and can introduce misconfigurations. In AI environments, prompt changes and model updates often bypass established change-control policies.

Availability

- *Service Disruption and Outages:* In cloud and AI environments a configuration error is rarely limited to one service. A misconfigured dependency can take down multiple workflows. The origin is often not obvious until well after disruption begins.
- *Loss of Critical Data Access and Services:* Disruptive failures occur when data becomes inaccessible. The problem surfaces when users try to use the resource and find it unavailable. Recovery requires restoring the approved configuration. Teams must then verify that affected services are operating normally before users can resume their work.

BUSINESS IMPACT

Financial

- *Remediation Costs:* A misconfigured storage bucket can trigger weeks of forensic analysis. Regulatory notification and customer communication follow before the incident is closed. The cost of remediation is almost always far greater than the cost of the original error.
- *Non-compliance and Fines:* Regulators often view missing change control documentation as evidence of a wider governance failure. That shifts the conversation from a single incident to systemic control failure. Enforcement actions become harder to resolve, and penalties harder to negotiate.
- *Lost Revenue:* Publicly exposed services, data breaches, and service outages disrupt business operations. Transactions are delayed or interrupted, affecting revenue and customer service. Customer confidence is harder to recover than the system.

Operational

- *System Performance Degradation:* Incorrect configurations reduce service reliability. Latency increases. Automated workflows fail. AI inference performance degrades. These problems are difficult to diagnose because they might not generate the error patterns monitoring tools watch for. Degraded performance can continue a long time before anyone notices a problem.
- *System Outages:* Misconfigured infrastructure, dependencies, orchestration workflows, or updates interrupt critical services. Small errors cascade. Multiple connected systems fail before the source is identified.
- *Operational Recovery Effort:* Recovery is not just a technical exercise. Teams must validate changes, restore services, and verify affected systems before operations can resume. That process frequently uncovers additional misconfigurations, which were not part of the original incident.

Compliance

- *Regulatory Violations:* Misconfigured cloud and AI environments can violate data protection, privacy, cybersecurity, and industry-specific requirements. The violation is rarely the misconfiguration itself — it is the exposed data, the missing control, or the undocumented change which regulators find behind it.
- *Audit Findings:* The same finding in repeated audits tells regulators the organization is not fixing the underlying cause. That conclusion carries more weight than any individual finding.
- *Policy Non-conformance:* Unauthorized configuration changes violate approved baselines and internal governance requirements. In regulated environments, the absence of an approval record is itself a compliance finding, whether or not the change caused harm.

Reputational

- *Company Reputation:* Public disclosure of a misconfiguration causes more reputational damage than the technical impact of the error. High-profile incidents attract attention that the technical team is not equipped to handle. Questions about organizational competence follow, even when the underlying mistake was relatively simple.
- *Stakeholder Assurance:* Misconfigurations reduce confidence among customers, partners, regulators, and investors. They raise questions about whether security and oversight processes are working as intended. Restoring stakeholder trust requires audits, reporting, or independent assurance beyond fixing the technical problem.
- *Customer Confidence:* Customers generally do not distinguish between a breach caused by a software exploit and one caused by a misconfiguration. Repeated incidents discourage customers from sharing sensitive data, adopting new services, or expanding their use of existing ones. Over time, that hesitation results in customer attrition and lost business.

KEY TAKEAWAYS

- **Prevent unauthorized exposure of cloud and AI services:** Cloud resources, AI services, storage repositories, inference endpoints, vector databases, and management interfaces must not be deployed or left publicly accessible without authentication and appropriate access controls. Default configurations require regular review. Any external exposure must be intentional, documented, and approved.
- **Validate configuration changes through formal change control:** Configuration changes require testing, validation, and independent review before reaching production. No high-risk change affecting cloud infrastructure, AI models, orchestration workflows, access-control policies, or security monitoring systems should reach production without independent approval.
- **Continuously monitor for configuration drift and unintended exposure:** Automated controls must identify exposed services, publicly accessible storage, excessive permissions, disabled security controls, and deviation from approved configurations. Misconfigurations which are not caught quickly often become part of the environment.
- **Secure sensitive data, credentials, and logs by default:** Training data, embeddings, model artifacts, credentials, and logs should all be treated as sensitive assets. Logging,

debugging, and analytics systems are common sources of exposure. They require the same configuration review as production systems.

- **Implement secure configuration baselines and automated validation:** Approved baselines should cover cloud services. They should also cover AI infrastructure, storage platforms, networking components, and operational tooling. Implement IaC validation and policy enforcement. Automated compliance checks catch what manual review misses. Automated compliance checks catch what manual review misses.
- **Apply least-privilege access to cloud and AI environments:** Every permission assigned to a user, service account, application, agent, or AI workflow should be the minimum required for that function. Permissions need to be continuously reviewed so they don't accumulate. Accumulated permissions become the path of least resistance for attackers.
- **Employ containment:** Organizations should investigate and remediate misconfigurations before they become permanent exposures. Where appropriate, automated remediation — such as restoring approved configurations or removing unintended public access — can reduce exposure time.

ANECDOTES AND EXAMPLES

Recent incidents resulting from misconfiguration and inadequate change control include:

- **(April 2024)** Veritone Government AI Training Data: In April 2024, Cyberinsider reported on UpGuard research identifying misconfigured Elasticsearch databases in a government cloud environment, exposing approximately 550 GB of data across 1.6 billion records. The exposed data included law-enforcement video, audio, transcripts, annotated datasets, and authentication tokens used in machine-learning workflows. The incident demonstrated how misconfigured cloud services can expose large volumes of sensitive operational and training data. Remediation included securing access controls and strengthening configuration management practices [6].
- **(January–February 2025)** DeepSeek AI Database Exposure: Wiz researchers identified a publicly accessible ClickHouse database used by DeepSeek's AI infrastructure. The database lacked authentication and exposed more than 1,000,000 log entries — including chat prompts, metadata, environment variables, and API keys. The incident demonstrated how improperly secured AI infrastructure can expose sensitive operational information and internal service data through publicly accessible cloud resources. The issue was remediated through access restrictions, authentication enforcement, and improved configuration governance [7][8].
- **(August 2025)** AI Chatbot Conversation Exposure: UpGuard reported a security flaw in certain AI chatbot platforms that exposed user conversations, including highly sensitive and explicit content, via misconfigured logging or publicly accessible endpoints. The incident demonstrated how debugging, analytics, and monitoring systems can become unintended sources of data exposure when access controls and configuration reviews are inadequate. Affected operators remediated the issue by restricting access, correcting configurations, and strengthening logging and deployment controls [9][10].

- **(May 2026)** Hospitality Check-In Cloud Data Exposure: In May 2026, security researcher Anurag Sen disclosed a cloud storage misconfiguration affecting an identity-processing platform integrated with major hotel properties. An unsecured storage bucket exposed more than one million identity-verification records — including high-resolution scans of passports, driver's licenses, traveler registration records, and other Personally Identifiable Information (PII). The incident demonstrated how publicly accessible cloud storage can expose large volumes of sensitive data without requiring exploitation of a software vulnerability. Remediation included isolating the exposed storage environment, restricting public access, and correcting the underlying cloud configuration weaknesses [11][12].

CSA CBK SECURITY GUIDANCE VERSION 5.0

Domain 3: Risk, Audit, & Compliance
Domain 4: Organization Management
Domain 5: Identity & Access Management
Domain 6: Security Monitoring
Domain 7: Infrastructure & Networking
Domain 8: Cloud Workload Security
Domain 9: Data Security
Domain 10: Application Security
Domain 11: Incident Response & Resilience
Domain 12: Related Technologies & Strategies

CSA AICM CONTROLS VERSION 1.1

CCC Change Control and Configuration Mgt
 CCC-01: Change Management Policy and Procedures
 CCC-02: Quality Testing
 CCC-03: Change Management Technology
 CCC-06: Change Management Baseline
 CCC-07: Detection of Baseline Deviation

IAM Identity & Access Management
 IAM-03: Identity Inventory
 IAM-05: Least Privilege
 IAM-08: Access Review
 IAM-15: Authorization Mechanisms
 IAM-18: Agent Access Restriction

I&S Infrastructure Security
 I&S-03: Network Security
 I&S-04: OS Hardening and Base Controls
 I&S-06: Segmentation and Segregation

DSP Data Security and Privacy Lifecycle Management
 DSP-01: Security and Privacy Policy and Procedures
 DSP-03: Data Inventory
 DSP-04: Data Classification
 DSP-05: Data Flow Documentation
 DSP-17: Sensitive Data Protection

LOG Logging and Monitoring
 LOG-03: Security Monitoring and Alerting
 LOG-05: Audit Logs Monitoring and Response
 LOG-07: Logging Scope

AIS Application & Interface Security
 AIS-02: Application Security Baseline Requirements
 AIS-08: API Security
 AIS-11: Agents Security Boundaries
 AIS-13: AI Sandboxing

MDS Model Security

MDS-02: Model Artifact Scanning

MDS-08: Model Integrity Checks

MDS-10: Model Continuous Monitoring

TVM Threat & Vulnerability Management

TVM-07: Penetration Testing

TVM-08: Vulnerability Remediation Schedule

TVM-09: Vulnerability Prioritization

Reference Links

1. Cloud Security Alliance. "Misconfiguration: Taming Change Control." August 2024.
cloudsecurityalliance.org/blog/2024/08/20/top-threat-1-misconfig-misadventures-taming-the-change-control-chaos
2. NIST. "Artificial Intelligence Risk Management Framework (AI RMF 1.0)." NIST AI 100-1. January 2023, p. 4.
doi.org/10.6028/NIST.AI.100-1
3. Schneider, Christian. "RAG Security: The Forgotten Attack Surface." February 2026.
christian-schneider.net/blog/rag-security-forgotten-attack-surface/
4. Google Cloud. "Threat Horizons Report H1 2025." Google Cloud Threat Intelligence. 2025.
services.google.com/fh/files/misc/threat_horizons_report_h1_2025.pdf
5. Wiz. "AI Misconfigurations: Examples and Attack Paths." December 2025.
www.wiz.io/academy/ai-security/ai-misconfigurations
6. Cyberinsider. "Security Lapse at Veritone AI Exposes Vast Amounts of US Govt Data"
cyberinsider.com/security-lapse-at-veritone-ai-exposes-vast-amounts-of-us-govt-data/
7. Wiz Research. "DeepSeek Logging Database Exposure."
www.wiz.io/blog/wiz-research-uncovers-exposed-deepseek-database-leak
8. Wired. "Exposed DeepSeek Database Revealed Chat Prompts and Internal Data."
www.wired.com/story/exposed-deepseek-database-revealed-chat-prompts-and-internal-data/
9. UpGuard. "Security Flaw in AI Chatbots Exposes Explicit User Fantasies."
www.upguard.com/news/security-flaw-in-ai-chatbots-exposes-explicit-user-fantasies
10. Incident 1020: Reportedly Unsafe Deployment of Llama.cpp Reveals Interactive AI-Generated CSAM Roleplay Prompts
incidentdatabase.ai/cite/1020/
11. SecureTheLeaks. "Hospitality Check-In Cloud Data Exposure." Intel Reports, May 2026.
www.securetheleaks.com/ (accessed via View Intel Reports)
12. TechCrunch. "A Hotel Check-In System Left a Million Passports and Driver's Licenses Open for Anyone to See." May 15, 2026.
techcrunch.com/2026/05/15/a-hotel-check-in-system-left-a-million-passports-and-drivers-licenses-open-for-anyone-to-see/

AI System Compromise

AI System Compromise is defined as the exploitation, manipulation, degradation, or unauthorized control of systems that embed artificial intelligence or machine learning components within their functionality. These threats target not only the surrounding infrastructure in which AI operates, but also AI-enabled components, including models, prompts, training and inference data, orchestration logic, connected tools, and decision pipelines. Guidance from NIST, CISA, NCSC, and ENISA recognizes that AI systems introduce attack surfaces beyond conventional software [1][2][3][4].

Common AI Attack Vectors:

- Prompt injection and input manipulation
- Data or model poisoning
- Adversarial or evasive inputs
- Model theft or inference attacks
- Compromise of connected models, APIs, plugins, or pipelines

The NCSC warns that AI systems introduce security vulnerabilities which must be considered alongside conventional cyber threats. Techniques such as prompt injection, exploitation of software vulnerabilities, and supply chain compromise may enable exploitation of AI systems and facilitate access to broader enterprise environments. CISA, NSA, and partner guidance similarly emphasize that weaknesses in data, models, and connected services can affect the accuracy, integrity, and trustworthiness of AI-enabled outcomes across the system lifecycle [6][7].

Unlike a traditional application compromise, an AI system compromise can occur without fully breaching the host environment. An attacker may manipulate how the system interprets inputs, influences outputs, or triggers downstream actions. Compromise may result in unauthorized disclosure of sensitive information, model misclassification, unsafe automation, corruption of

decision support, or unintended execution of connected functions. NIST's adversarial machine learning taxonomy and CISA guidance emphasize that attacks occur across the AI lifecycle, from data collection and model development through deployment and operation[1][5].

AI systems may also blur the boundary between data and instructions. NCSC warns that current Large Language Models (LLMs) do not enforce a reliable security boundary between instructions and data inside prompts, making prompt injection different from classical injection flaws. OWASP identifies prompt injection as a leading risk because hostile content can alter system behavior, disclose sensitive information, or invoke connected capabilities in unintended ways. AI-specific weaknesses may also lead to familiar compromises including credential theft, code execution, data exfiltration, unauthorized actions, or persistence within trusted workflows — particularly where AI systems can read files, call APIs, access repositories, or influence operational or security-relevant decisions [2][4].

TECHNICAL IMPACT

Confidentiality

- *Disclosure of Data:* Manipulated prompts, insecure integrations, or misuse of AI-connected tools may expose prompts, training data, inference data, model outputs, credentials, logs, or connected data sources.

Integrity

- *Manipulation of Outputs or Decisions:* Altered prompts, inputs, models, or AI workflows may result in incorrect outputs, corrupted decision support, unsafe automation, or unauthorized downstream actions.

Availability

- *Disruption of AI Services or Workflows:* Compromised AI functions may degrade model reliability, disrupt AI-enabled workflows, or necessitate service suspension during investigation and recovery.

BUSINESS IMPACT

Operational

- *Disruption of Business Processes:* Compromised AI systems may disrupt business operations by producing degraded outputs, delaying decisions, interrupting workflows, or triggering manual fallback processes.
- *Reduced Reliability of Decision-Making:* Manipulated prompts, corrupted data, or degraded model behavior may lead to incorrect, unsafe, or unauthorized decisions in AI-enabled environments.
- *Increased Incident Response Complexity:* Compromise of an AI system may complicate investigation and recovery by requiring validation of outputs, restoration of automated functions, or retraining of affected models.

Financial

- *Increased Recovery and Remediation Costs:* A compromise of an AI system may incur costs for investigation, remediation, model retraining, legal support, customer notification, or service restoration.
- *Loss of Sensitive or Proprietary Assets:* Compromise may expose proprietary models, prompts, training data, credentials, or source code, resulting in financial loss or competitive disadvantage.
- *Business Interruption and Assurance Costs:* Compromised AI-enabled systems may increase costs due to downtime, manual workarounds, output validation, or the need to restore trust in automated functions.

Compliance

- *Violation of AI-Specific Regulatory Requirements:* Compromise of AI systems may constitute a breach of emerging AI governance frameworks — including the EU AI Act, sector-specific AI guidance, or national cybersecurity regulations — which impose obligations on the integrity, transparency, and security of AI-enabled systems.
- *Breach of Data Protection and Privacy Obligations:* Unauthorized disclosure of training data, inference inputs, or connected data sources through AI compromise may trigger obligations under GDPR, CCPA, HIPAA, or other data protection regimes — including breach notification, regulatory reporting, and remediation requirements.
- *Failure of AI Governance and Audit Accountability:* Manipulation of AI outputs, decision pipelines, or orchestration logic can undermine an organization's ability to demonstrate auditability, explainability, and control over AI-enabled decisions, creating compliance exposure in regulated industries where automated decisions are subject to oversight or challenge.

Reputational

- *Loss of Trust in AI Systems:* Compromise of AI-enabled systems may reduce confidence in automated outputs, decisions, or customer-facing interactions.
- *Damage to Organizational Credibility:* Exposure of sensitive data, unsafe actions, inaccurate outputs, or failures in AI governance can damage reputation and reduce stakeholder confidence.
- *Regulatory and Public Scrutiny:* AI-related incidents involving privacy, surveillance, unsafe automation, or disclosure of sensitive information may attract regulatory attention, legal scrutiny, or negative public attention.

KEY TAKEAWAYS

- **Protect AI-enabled components:** Secure not only infrastructure but also models, prompts, training and inference data, orchestration logic, connected tools, and AI pipelines.
- **Prevent manipulation of AI behavior:** Implement safeguards against prompt injection, poisoning, adversarial inputs, model theft, and insecure integrations which may alter outputs or trigger unauthorized actions.

- **Treat AI systems as part of the attack surface:** Apply security controls across the AI lifecycle, including data collection, model development, deployment, inference, and operation.
- **Limit the downstream impact of compromise:** Restrict AI access to files, APIs, repositories, and sensitive systems through least privilege, segmentation, approval workflows, and monitoring. Controls should also limit what an AI system can retrieve in the first place, through RAG/data-scope minimization, and restrict where it can send data using egress allow-listing and DLP controls on outputs.
- **Continuously validate trustworthiness of outputs:** Monitor for unexpected model behavior, data leakage, unsafe automation, and degradation of decision quality, any of which may indicate compromise.

ANECDOTES AND EXAMPLES

Recent incidents resulting from AI system compromise include:

- **(2025)** GitHub Copilot was fully compromised via prompt injection, with self-replicating “ZombAI” worm capability across developer repositories. Researcher Johann Rehberger and Persistent Security independently discovered CVE-2025-53773, which allowed malicious instructions embedded in source code comments, README files, GitHub Issues, or web content — including invisible Unicode characters — to manipulate Copilot into silently enabling “YOLO mode” by modifying the project’s .vscode/settings.json configuration file. With “YOLO mode” active, Copilot could run shell commands, browse the Internet, and perform privileged actions without user confirmation. Beyond the primary exploit, researchers demonstrated that the attack could create AI viruses that propagate through infected repositories, automatically embedding malicious instructions in new projects and recruiting developer workstations into botnets. Microsoft patched the vulnerability in the August 2025 Patch Tuesday. AI agents that can modify their own configuration files or security-relevant settings without user approval create a path from prompt manipulation to full host compromise. Self-modification capabilities must be treated as a privileged operation requiring explicit human approval.
- **(2025)** The first zero-click AI vulnerability — EchoLeak — enabled silent enterprise data exfiltration through a single crafted email, with no user interaction required. EchoLeak (CVE-2025-32711, CVSS 9.3) was disclosed by Aim Security researchers in June 2025. By sending a single email, with no user interaction required, an attacker could cause Microsoft 365 Copilot to access internal files and exfiltrate their contents to an attacker-controlled server. The attack exploited Copilot’s RAG architecture: the malicious email sat unnoticed in the mailbox — users did not need to interact with it — and Copilot’s normal retrieval process incorporated the hidden instructions into subsequent AI-assisted queries. Potentially exposed information included anything within Copilot’s access scope: chat logs, OneDrive files, SharePoint content, Teams messages, and other preloaded organizational data. Microsoft patched the specific vulnerability on the server side before public disclosure, and claimed that no exploitation in the wild occurred. AI assistants with broad access to enterprise data stores must be treated as privileged data processors: the scope of what a

model can retrieve must be constrained before it can access it, not merely patched after exfiltration is demonstrated.

- **(2025)** Compromise of the Salesloft Drift AI chatbot integration enabled attackers to silently exfiltrate data from over 700 organizations — including major security vendors — without further exploiting any vulnerability in the victim environments. In August 2025, threat cluster UNC6395 stole OAuth authentication tokens from Salesloft’s Drift chatbot integration. Using those tokens attackers impersonated the trusted Drift application to gain unauthorized access to customer Salesforce, Google Workspace, and Slack environments, exfiltrating sensitive contact records, CRM data, API keys, Snowflake tokens, and cloud credentials embedded in support cases. Traditional monitoring failed because the activity originated from a trusted, pre-approved integration — OAuth tokens made attacker queries indistinguishable from legitimate chatbot activity. Enterprises could see that Drift had access, but not what it was actually doing with that access. Confirmed victims included Cloudflare, Palo Alto Networks, Zscaler, and PagerDuty. AI-powered SaaS integrations that grant persistent OAuth access to enterprise systems are under-monitored high-value attack surface. Third-party AI tool access must be scoped to the minimum necessary permissions, continuously monitored for anomalous behavior, and subject to regular access review — the same scrutiny applied to any privileged application.
- **(2026)** A supply chain attack on LiteLLM — the AI industry’s most widely used multi-provider API gateway — gave attackers persistent access to the entire AI credential stacks of thousands of organizations. On March 24, 2026, threat actor group TeamPCP gained access to the LiteLLM maintainer’s PyPI publishing credentials and pushed malicious versions (1.82.7 and 1.82.8) to the package index. The payload executed silently — no explicit import was needed — using Python’s .pth file mechanism, which auto-executes code every time the Python interpreter starts. The malicious code executed during normal library usage, targeting LLM API keys, cloud provider secrets, SSH keys, Kubernetes cluster credentials, and environment variables across developer workstations, CI/CD pipelines, and production environments. The attack was part of a broader, multi-ecosystem campaign spanning PyPI, npm, Docker Hub, GitHub Actions, and OpenVSX, all in a single coordinated operation. LiteLLM’s position as a unified gateway to multiple AI providers made it uniquely dangerous: compromising a single dependency granted credential access to many organizations’ entire AI stacks. AI infrastructure dependencies must be treated as critical supply chain risk — pinned versions, integrity verification, and least-privilege credential scoping are non-negotiable for packages that sit between applications and AI provider APIs.

CSA CBK SECURITY GUIDANCE VERSION 5.0

Domain 3: Risk, Audit, and Compliance

Domain 5: Identity and Access Management

Domain 6: Security Monitoring

Domain 7: Infrastructure & networking

Domain 8: Cloud Workload Security

Domain 9: Data Security

Domain 10: Application Security

Domain 11: Incident Response & Resilience

Domain 12: Related Technologies & Strategies

CSA AICM CONTROLS VERSION 1.1

AIS Application & Interface Security

AIS-05: Application Security Testing
AIS-07: Application Vulnerability Remediation
AIS-08: Input Validation
AIS-09: Output Validation
AIS-10: API Security
AIS-11: Agents Security Boundaries
AIS-13: AI Sandboxing
AIS-15: Prompt Differentiation

DSP Data Security & Privacy

DSP-05: Data Flow Documentation
DSP-17: Sensitive Data Protection
DSP-21: Data Poisoning Prevention & Detection
DSP-23: Data Integrity Check

GRC Governance, Risk & Compliance

GRC-02: Risk Management Program
GRC-10: AI Impact Assessment
GRC-15: Human Supervision

I&S Identity & Access Management

IAM-05: Least Privilege
IAM-08: User Access Review
IAM-15: Passwords and Secrets Management
IAM-16: Authorization Mechanisms
IAM-19: Agent Access Restriction

LOG Logging & Monitoring

LOG-03: Security Monitoring and Alerting
LOG-13: Failures and Anomalies Reporting
LOG-14: Input Monitoring
LOG-15: Output Monitoring

MDS Model Security

MDS-01: Training Pipeline Security
MDS-02: Model Artifact Scanning
MDS-06: Adversarial Attack Analysis
MDS-08: Model Integrity Checks
MDS-09: Model Signing/Ownership Verification
MDS-10: Model Continuous Monitoring
MDS-12: Open Model Risk Assessment

SEF Security Incident Management, E-Discovery, & Cloud Forensics

SEF-03: Incident Response Plans
SEF-06: Event Triage Processes
SEF-07: Security Breach Notification

STA Supply Chain Management, Transparency & Accountability

STA-01: Supply Chain Risk Management Policies
STA-09: Supply Chain Risk Management
STA-14: Supply Chain Governance Review
STA-15: Supply Chain Data Security Assessment
STA-16: Service Bill of Material (BOM)

TVM Threat & Vulnerability Management

TVM-02: Malware and Malicious Instructions Protection
TVM-05: External Library Vulnerabilities
TVM-11: Guardrails
TVM-12: Threat Analysis and Modeling
TVM-13: Threat Response

Reference Links

1. Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations
csrc.nist.gov/pubs/ai/100/2/e2025/final
2. Guidelines for secure AI system development
www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development
3. AI Cybersecurity Collaboration Playbook
www.cisa.gov/resources-tools/resources/ai-cybersecurity-collaboration-playbook
4. Securing Machine Learning Algorithms
www.enisa.europa.eu/publications/securing-machine-learning-algorithms
5. JCDC AI Cybersecurity Collaboration Playbook
www.cisa.gov/sites/default/files/2025-01/JCDC%20AI%20Playbook.pdf
6. AI Cybersecurity Collaboration Playbook
www.cisa.gov/resources-tools/resources/ai-cybersecurity-collaboration-playbook
7. Impact of AI on cyber threats from now to 2027
www.ncsc.gov.uk/sites/default/files/pdfs/publication/impact-ai-cyber-threat-now-2027.pdf

Advanced Persistent Threats



Advanced Persistent Threats (APTs) are defined as coordinated, resource-intensive cyber operations conducted by highly capable adversaries, most commonly state-sponsored groups or actors aligned with national strategic objectives. These campaigns are characterized by sustained access to target environments, operational patience, and the prioritization of intelligence collection, pre-positioning, or strategic disruption over immediate financial gain [1]. Unlike opportunistic cybercrime, APT activity is typically targeted, iterative, and adaptive, with intrusion efforts refined over extended periods in response to defender actions and environmental constraints [2].

Advanced Persistent Threats in cloud environments involve campaigns against identity, control planes, and trusted relationships. In cloud-native and hybrid estates, threat actors increasingly target privileged cloud accounts, service principals, managed identities, federation trusts, OAuth tokens, and CI/CD service connections because these provide durable access that can survive workload churn and extend across subscriptions, tenants, and connected SaaS services. [14][15].

In the 2025–2026 threat landscape, APT activity has been increasingly shaped by geopolitical competition, with campaigns aligned to national priorities including economic intelligence gathering, surveillance of communications infrastructure, and establishment of footholds within critical national systems. Governments across the world have reported on continued targeting of telecommunications providers, cloud and managed service ecosystems, software supply chains, and Internet-facing network infrastructure. The targeting of these sectors is likely motivated by the value of data reachable through them, with these sectors selected primarily as aggregation points, through which access to multiple downstream organizations can be obtained. [2][7][8].

Tradecraft in recent APT operations is evolving towards persistence through low-visibility techniques. Known vulnerabilities, misconfigurations, and insufficiently secured edge devices continue to provide reliable entry points, reducing the need for costly zero-day exploits [4]. Once access is established

credential theft, identity abuse, and lateral movement across hybrid environments are used to maintain presence while minimizing detection. Increasingly, compromises are designed to remain dormant or partially active — enabling adversaries to return to pre-established access points when required.

Recent developments further indicate that artificial intelligence is being incorporated into APT methods as a force multiplier rather than a replacement for established techniques. AI has been observed enhancing reconnaissance, improving the plausibility and targeting of social engineering, and enabling rapid adaptation of malicious code and infrastructure. APT operations are becoming more scalable and responsive, while retaining their core characteristics: stealth, persistence, and strategic intent. This convergence of traditional intrusion methods with AI-enabled augmentation represents a significant evolution in both the efficiency and reach of advanced threat actors [3][5][6].

TECHNICAL IMPACT

Confidentiality

- *Unauthorized Access and Exfiltration of Data:* Persistent access established by APT actors may enable the covert collection and exfiltration of sensitive information, including credentials, communications, intellectual property, and operational data. Compromised identity systems, network traffic interception, or access to cloud and endpoint environments may result in prolonged, undetected exposure of critical data.

Integrity

- *Manipulation of Systems and Data:* APT actors may alter system configurations, modify logs, or tamper with data and software to maintain persistence and evade detection. Such activity may compromise the accuracy and reliability of information, introduce hidden backdoors, and reduce confidence in system outputs and audit trails.

Availability

- *Disruption of Systems or Services:* Although not always the primary objective, the presence of an APT may degrade system performance, disrupt critical services, or enable future targeted outages. Pre-positioned access may be leveraged to deny system availability, delay recovery efforts, or disrupt operational continuity at strategically significant moments.

BUSINESS IMPACT

Operational

- APTs may disrupt normal operations by compromising the reliability of systems, communications, and identities. They can introduce uncertainty into incident response by obscuring the scope and duration of compromise. In environments supporting critical or time-sensitive functions such activity can increase the risk of service degradation, delayed response, and loss of operational control.

Financial

- APTs can incur high direct and indirect costs. These may include expenditure on investigation, remediation, legal processes, and security enhancements. Financial impact can also arise from loss of intellectual property, regulatory penalties, contractual liabilities, and reduced commercial advantage. Sustained exposure increases the cost of maintaining secure and resilient operations.

Compliance

- APT activity may result in unauthorised access to sensitive or regulated data, including personal, financial, and healthcare information. Prolonged undetected compromise may lead to breaches of data protection, privacy, cybersecurity, or industry-specific regulatory requirements. This may trigger mandatory breach notification, regulatory investigation, penalties, and increased scrutiny from supervisory authorities.

Reputational

- APTs can damage organizational reputation by demonstrating an inability to prevent prolonged, covert compromise. This may reduce stakeholder confidence, particularly where sensitive data, critical services, or trusted relationships are affected. Reputational harm can extend beyond the organization itself, especially if it is perceived as a conduit for broader compromise among partners or customers.

KEY TAKEAWAYS

- Follow the best practices discussed in the Security Issue 01: Inadequate Identity and Access Management and Security Issue 05: Misconfiguration and Inadequate Change Control sections of this publication, specifically:
 - **Enforce Least Privilege to Limit Impact Scope:** Ensure entities have only the access rights needed to perform their tasks.
 - **Prevent unauthorized exposure of cloud and AI services:** Cloud resources, AI services, storage repositories, inference endpoints, vector databases, and management interfaces must not be deployed or left publicly accessible without authentication and appropriate access controls.
 - **Secure sensitive data, credentials, and logs by default:** Training data, embeddings, model artifacts, credentials, and logs should all be treated as sensitive assets. Logging, debugging, and analytics systems are common sources of exposure.
- Continuously monitor cloud resources for known vulnerabilities and misconfigurations [9].
- Proactive threat-hunting capabilities should be strengthened to improve visibility into low-level, long-duration adversary activity [9].
- Timely patch management, secure configuration of edge devices, and robust identity and access controls should be implemented to reduce common entry points and limit lateral movement [9].

ANECDOTES AND EXAMPLES

Recent examples of issues related to APTs, organized crime, and hackers:

- **(Late 2025)** The BRICKSTORM espionage campaign — attributed to a China-aligned threat actor, targeted organizations across the legal services, SaaS, and business process outsourcing sectors. The campaign focused on entities which provide services to other organizations, enabling indirect access to downstream clients and sensitive data. This activity illustrated the increasing priority of initial access and persistence in APT campaigns, where initial compromise of a single provider can facilitate broader infiltration across interconnected ecosystems [10][11].
- **(April 2026)** A supply chain compromise that began with the npm package axios was attributed to the North Korean threat actor Sapphire Sleet. The packages were designed to appear legitimate while embedding malicious functionality that could exfiltrate sensitive data and credentials. This incident underscored continued APT focus on developer ecosystems and open source repositories, where trust relationships can be exploited to achieve wide distribution and downstream compromise [12].
- **(April 2026)** APT28 (Russian military intelligence) was reported to have exploited vulnerable Internet routers to conduct DNS hijacking and credential interception. By manipulating network infrastructure rather than endpoints, the operation enabled covert surveillance and harvesting of authentication data. This activity demonstrated the effectiveness of targeting overlooked or weakly secured edge devices to achieve persistence and evade conventional endpoint-focused detection [13].

CSA CBK SECURITY GUIDANCE VERSION 5.0

Domain 1: Cloud Computing Concepts and Architecture

Domain 3: Risk, Audit, & Compliance

Domain 5: Identity & Access Management

Domain 8: Cloud Workload Security

Domain 9: Data Security

Domain 10: Application Security

Domain 11: Incident Response & Resilience

CSA AICM CONTROLS VERSION 1.1

IAM Identity & Access Management

IAM-03: Identity Inventory
IAM-05: Least Privilege
IAM-08: Access Review
IAM-15: Authorization Mechanisms
IAM-18: Agent Access Restriction

LOG Logging and Monitoring

LOG-03: Security Monitoring and Alerting
LOG-05: Audit Logs Monitoring and Response

SEF Security Incident Mgt, E-Discovery, & Cloud Forensics

SEF-03: Incident Response Plans
SEF-04: Incident Response Testing

STA Supply Chain Management, Transparency, and Accountability

STA-08: Supply Chain Risk Management

TVM Threat and Vulnerability Management

TVM-01: Threat and Vulnerability Management Policy and Procedures
TVM-02: Malware Protection Policy and Procedure
TVM-03: Vulnerability Remediation Schedule
TVM-04: Detection Updates
TVM-06: Penetration Testing

Reference Links

1. Office of the Director of National Intelligence (ODNI): Annual Threat Assessment of the U.S. Intelligence Community 2025
www.dni.gov/files/ODNI/documents/assessments/ATA-2025-Unclassified-Report.pdf
2. UK Parliament: Cyber Security of UK Critical National Infrastructure (Research Briefing)
researchbriefings.files.parliament.uk/documents/CBP-10417/CBP-10417.pdf
3. NetAskari: Train to Kill: China's Secret Training Platform
netaskari.substack.com/p/train-to-kill-chinas-secret-training
4. CrowdStrike: 2026 Global Threat Report
www.crowdstrike.com/explore/2026-global-threat-report/
5. Microsoft Threat Intelligence: Jasper Sleet – North Korean Remote IT Workers' Evolving Tactics to Infiltrate Organizations
www.microsoft.com/en-us/security/blog/2025/06/30/jasper-sleet-north-korean-remote-it-workers-evolving-tactics-to-infiltrate-organizations/
6. UK Cyber Security Council: The Next Frontier in Cyber Conflict: AI-Driven Malware and Autonomous Attack Chains
www.ukcybersecuritycouncil.org.uk/blogs/the-next-frontier-in-cyber-conflict-ai-driven-malware-and-autonomous-attack-chains
7. CISA: Countering Chinese State-Sponsored Actors' Compromise of Networks Worldwide to Feed a Global Espionage System
www.cisa.gov/news-events/cybersecurity-advisories/aa25-239a
8. NSA and Partners: Guidance to Counter China State-Sponsored Actors Targeting Telecommunications and Critical Infrastructure
www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4287371/nsa-and-others-provide-guidance-to-counter-china-state-sponsored-actors-targeti/
9. Advanced Persistent Threat (APT) Mitigation in Cloud Platforms
dev.to/iskender83/advanced-persistent-threat-apt-mitigation-in-cloud-platforms-245a

10. Google Cloud / Mandiant: BRICKSTORM Espionage Campaign
cloud.google.com/blog/topics/threat-intelligence/brickstorm-espionage-campaign
11. NSA and CISA: Detecting BRICKSTORM Backdoor Activity
www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/Article/4348338/nsa-joins-cisa-to-release-guidance-on-detecting-brickstorm-backdoor-activity/
12. North Korea-Nexus Threat Actor Compromises Widely Used Axios NPM Package in Supply Chain Attack
cloud.google.com/blog/topics/threat-intelligence/north-korea-threat-actor-targets-axios-npm-package
13. NCSC: UK Exposes Russian Military Intelligence Hijacking Vulnerable Routers for Cyber Attacks
www.ncsc.gov.uk/news/uk-exposes-russian-military-intelligence-hijacking-vulnerable-routers-for-cyber-attacks
14. Scattered Spider and the Cloud Control Plane: stealthy identity threats
www.acalvio.com/identity-security/scattered-spider-and-the-cloud-control-plane-stealthy-identity-threats/
15. Securing Core Cloud Identity Infrastructure: Addressing Advanced Threats through Public-Private Collaboration
www.cisa.gov/news-events/news/securing-core-cloud-identity-infrastructure-addressing-advanced-threats-through-public-private

Lacking Cloud Security Strategy and Governance

Inadequate cloud security strategy or the inability to implement one represents a fundamental failure of business control: the inability to state with confidence which cloud technologies are in use, where sensitive data resides, and whether a threat can be detected and stopped before it causes harm.

A cloud security strategy defines how an organization approaches cloud adoption as a risk discipline: establishing shared responsibility boundaries, embedding security architecture into adoption decisions, assigning program-level ownership, and aligning cloud investment with regulatory obligations and risk appetite. Where that strategy exists and is sustained, governance structures follow from it — producing the inventory visibility, access controls, and monitoring capabilities that security programs depend on. Where it is absent or inadequate, cloud adoption proceeds with an insufficient architectural foundation, and governance gaps accumulate as a consequence.

Lack of a cloud security strategy is driven less by technical complexity than by adoption that has consistently outpaced the strategic and governance structures designed to contain it — leaving ungoverned identities, undocumented data flows, unsanctioned AI tools, and unreviewed third-party integrations operating across the enterprise without sufficient visibility or accountability.

The Cloud Security Alliance's December 2025 governance study confirmed that governance maturity is the strongest single predictor of an organization's ability to adopt AI securely — and that most organizations have not yet developed the strategic foundations required for maturity [1].

TECHNICAL IMPACT

Confidentiality

- *Disclosure of Data:* The confidentiality risk is that sensitive corporate, customer, and regulated data may be accessed, shared, exported, or processed outside approved security and privacy boundaries. This risk increases when the organization lacks a clear data classification model, access control architecture, SaaS integration review process, identity grant governance, or documented oversight of AI data flows. A cloud security strategy reduces this exposure by defining data classification requirements, access control principles, approved integration patterns, ownership expectations, and monitoring requirements. Without that foundation an organization may be unable to prove who has access to sensitive data; why that access exists; whether it remains appropriate; and whether the data is being used in accordance with business, regulatory, and contractual obligations.

Integrity

- *Unauthorized Modification and Credential Manipulation:* Where authentication controls and governance are weak, authentication configurations, privilege assignments, and cloud environment states may be modified in ways that go undetected by existing monitoring capabilities. Cloud security strategies that address privileged access architecture, identity provider governance, and change management as program-level disciplines establish the conditions under which authentication configurations, data stores, and cloud environment states remain under organizational control. Governance programs operating within that strategic framework define who holds privileged access, under what conditions it is granted, and how changes to cloud configurations are reviewed and validated. Where those program-level disciplines are in place, the integrity of cloud and AI environments is maintained through deliberate design.

Availability

- *Service Disruption and Loss of Operational Control:* Where these strategic and governance foundations are absent, third-party access, agent permissions, and credential lifecycles may present conditions that enable ransomware deployment, account compromise, or disruption of business-critical services. Cloud security strategies that treat third-party access as a program-level risk decision — establishing defined access boundaries, formal onboarding requirements, and continuous monitoring of third-party activity — establish conditions under which the blast radius of a third-party compromise remains contained. Governance programs that enforce MFA on privileged support channels, apply least-privilege principles to vendor access, and maintain current documentation of third-party permissions provide the controls that determine the scope of impact when third-party access is exploited.

BUSINESS IMPACT

Operational

- *Business Disruption:* Where third-party access is not governed through a cloud security strategy, a compromise affecting a vendor, service desk, or support pathway can propagate into core organizational systems and disrupt business operations. The April 2025 cyber incident affecting Marks & Spencer illustrates this operational impact: M&S reported that some personal customer data had been taken, online services were disrupted, and the company later estimated an approximately £300 million impact to operating profit for the year to March 2026. The impact is not limited to the initial compromise. Weak third-party access governance can reduce containment capacity during an incident by leaving unclear which vendor pathways exist, what privileges they hold, how they are monitored, and how quickly access can be restricted or revoked. This can result in extended service disruption, delayed recovery, lost sales, customer-service pressure, and supply-chain disruption.
- *Delayed Incident Response:* Where cloud security strategy does not establish a current inventory of cloud services, credentials, service accounts, automation scripts, and third-party integrations, incident response teams may be forced to begin containment by first discovering what assets, credentials, and access pathways exist. This can delay scoping, containment, credential rotation, and recovery, especially when credentials are embedded in scripts, applications, infrastructure templates, or automation tools.
- *Operational Blind Spots:* Where AI adoption is not governed through a cloud security strategy; unsanctioned AI tools and unmanaged integrations may process sensitive data outside approved security, privacy, and contractual boundaries. Security teams may lack visibility into which AI services are used, what data is submitted, how that data is retained, and whether anomalous usage or data leakage is occurring. The result is increased risk of data exposure, privacy violations, regulatory non-compliance, contractual breaches, and delayed detection of misuse.

Financial

- *Remediation and Recovery Costs:* Where cloud security strategy and governance are lacking, organizations may discover ungoverned cloud assets, data flows, credentials, service accounts, SaaS integrations, and AI usage involved in incidents. This can increase investigation complexity, delay containment, expand remediation effort, and raise recovery costs. IBM's Cost of a Data Breach Report 2025 placed the global average breach cost at \$4.44 million USD, and reported additional cost impact where shadow AI was involved. This supports the conclusion that weak governance over cloud, SaaS, and AI usage can create measurable financial exposure during breach response.
- *Regulatory Penalties:* Regulatory enforcement frameworks assess the strategic and governance conditions present at the time of an incident, not only the incident itself. The OCC's 2020 assessment of a \$80 million USD civil penalty against Capital One is instructive in this regard: the justification cited the organization's failure to establish effective risk assessment processes before migrating significant IT operations to the public cloud [5]. The finding was not that a control failed — it was that no cloud security strategy had been established to define what controls were required, who owned them, and how they

would be validated. This distinction — between a control failure and a strategic absence — reflects the standard that regulators of financial and operational resilience now apply to organizations operating in cloud environments.

- *Shadow AI Cost Amplification:* IBM's Cost of a Data Breach Report 2025 findings indicate that organizations with governed AI adoption programs experience measurably lower breach costs than those with high levels of unsanctioned AI usage, with the differential averaging \$670,000 USD per incident [2]. Cloud security strategies that establish AI tool authorization processes, maintain sanctioned registries, and document AI data flows yield quantifiable risk reduction — reflecting the protective effect of deliberate, strategic oversight applied consistently across an organization's AI activity.

Compliance

- *Regulatory Violations:* Where cloud security strategy and governance are lacking, organizations may be unable to determine whether required security, privacy, resilience, and data protection controls are operating effectively. As a result, regulated data may be processed through cloud services, SaaS platforms, AI tools, third-party integrations, or cross-border environments without documented risk assessment, approved legal basis, contractual assurance, access governance, retention controls, or monitoring. Regulatory exposure and fines may result. Under GDPR Article 83, certain infringements may result in administrative fines of up to 20 million EUR or 4% of total worldwide annual turnover, whichever is higher. In this context weak cloud governance can turn unmanaged cloud, SaaS, or AI adoption into a compliance failure — not only a technical weakness.
- *Audit Findings:* Where cloud governance is weak, organizations struggle to provide reliable evidence that cloud services are inventoried, access rights are reviewed, third-party controls are assessed, logging is enabled, sensitive data is classified, and exceptions are formally approved. Auditors and regulators may identify gaps not only because controls are missing, but also because ownership, evidence, monitoring, and validation are inconsistent, incomplete, or undocumented. This can lead to more audit findings, higher remediation and governance burden, delayed certifications, customer-assurance friction, and greater scrutiny from regulators, customers, insurers, and internal governance bodies. When evidence is assembled reactively for a specific assessment, rather than maintained continuously, the organization may be unable to demonstrate that cloud controls were operating effectively before the audit period or before a security incident.
- *Policy Non-Conformance:* Where cloud services, SaaS platforms, AI tools, and third-party integrations are adopted without a formal cloud security strategy, business units may bypass approved service onboarding, data classification, access review, architecture review, procurement, privacy, and third-party risk processes. This creates policy non-conformance across acceptable use, data handling, vendor management, identity governance, logging, encryption, monitoring, and incident-response. Cloud usage may continue outside approved policy boundaries which can create contractual exposure with customers and partners, weaken internal accountability, and increase the likelihood of policy deviations being discovered only during an audit, customer review, regulator inquiry, or security incident.

Reputational

- *Loss of Customer Trust:* When cloud security strategy and governance are missing entirely or deficient, organizations may struggle to provide customers with a narrative of security compliance. In a security incident organizations may fail to determine which systems were affected, what data was involved, which identities or integrations had access, whether third-party pathways contributed to the event, or what remediation was applied. Loss of customer confidence in the organization's security may follow, resulting in lost business.
- *Board and Executive Accountability:* When cloud governance is weak, boards and executives may face reputational scrutiny because the organization cannot demonstrate that cloud risks were identified, assessed, owned, monitored, and controlled, or that executive leadership provided a directive and oversight sufficient for effective security efforts. The Capital One penalty discussed above also shows how cloud risk governance failures rise to executive and board level: the OCC found not only inadequate risk assessment before the cloud migration but a failure to correct the deficiencies in a timely manner. CISA's April 2025 guidance on credential risks associated with a potential legacy Oracle Cloud compromise further reinforces the expectation that organizations understand credential exposure, credential reuse, embedded secrets, and cloud identity dependencies as part of their security governance obligations.
- *Market and Partner Confidence:* When an organization cannot demonstrate mature cloud governance, partners, customers, auditors, and insurers may question whether the organization can safely operate in interconnected cloud and SaaS environments. Weak visibility over cloud services, third-party integrations, AI usage, data locations, credentials, and monitoring coverage can undermine assurance during procurement, audits, renewals, incident review, and partnership discussions. CSA's December 2025 CSA/Google Cloud study found a clear link between mature governance and improved performance across AI adoption and security. This supports the broader conclusion that governance maturity is becoming a differentiator in cloud and AI security posture. Where governance is weak, the reputational impact is reduced confidence that the organization can manage emerging cloud, SaaS, and AI risks at enterprise scale.
- *Brand Damage from Repeated Visibility Failures:* When unmanaged cloud services, exposed credentials, public storage links, unsanctioned AI use, or missing logs are discovered only after an incident the market signal is that the organization lacks operational control. Repeated visibility failures can create the impression that security leadership is reactive, that risk ownership is unclear, and that cloud adoption has outpaced the organization's ability to govern it.
- The long-term reputational impact may include reduced customer trust, increased audit scrutiny, slower sales cycles, tougher security questionnaires, and cyber-insurance concerns. In regulated or high-trust sectors, this damage may persist even after the immediate technical issue has been remediated.

KEY TAKEAWAYS

- **You Cannot Defend What You Cannot See:** Effective cloud security governance is founded on the principle that security controls can only be applied to assets, identities, integrations, and data flows that are known, documented, and owned. Organizations that maintain current, governed inventories of cloud services, APIs, SaaS integrations, Non-Human Identities, and AI tools — including those adopted outside formal procurement channels — establish the foundational visibility security programs require to function. Governance investment in visibility produces compounding security returns across the threat landscape.
- **Identity Is the New Perimeter — and Most Organizations Are Leaving It Unlocked:** In cloud and AI environments identity represents the primary control plane through which access to data, systems, and services is granted and governed. Cloud security strategies that address identity as a program-level discipline — establishing enforced MFA, SSO coverage, least-privilege access models, periodic access reviews, privileged access management, and secret lifecycle governance — produce an access control posture that cloud environments require. CSA's 2026 State of Cloud and AI Security report found that organizations now manage a 100-to-1 ratio of machine to human identities, and that 78% of organizations lack formal policies governing the creation of AI identities [3]. Organizations that invest in identity governance as a strategic discipline establish a strong foundation for their security programs.
- **Define a cloud security strategy:** Establish an enterprise approach for governing cloud services, SaaS platforms, AI tools, identities, data flows, third-party integrations, monitoring, ownership, access control, vendor approval, incident response, and control validation.

ANECDOTES AND EXAMPLES

Incidents resulting from inadequate cloud security strategy and governance include:

- **(January–April 2025) Oracle Cloud — Legacy SSO Credential Exposure:** In early 2025, a threat actor exploited a Java vulnerability in a legacy Oracle Cloud environment to access Oracle's Identity Manager database, exfiltrating authentication data including usernames, hashed passwords, SSO credentials, and LDAP passwords. Security researchers confirmed that the exposure potentially affected over 140,000 Oracle Cloud tenants, with more than 6 million records reported in circulation. CISA issued guidance on April 16, 2025, noting that credential material embedded in scripts, automation tools, and IaC templates is particularly difficult to detect and can facilitate long-term unauthorized access across enterprise environments. The incident illustrates a governance failure characteristic of legacy cloud infrastructure: unpatched systems operating outside formal asset inventory, credential hygiene, and access monitoring programs [8].
- **(February–April 2025) Marks & Spencer — Absence of Strategic Security Architecture:** Beginning in February 2025, the Scattered Spider threat collective gained initial access to Marks & Spencer's environment by targeting the organisation's third-party IT service

provider, Tata Consultancy Services. Attackers persuaded a third-party service desk to reset internal credentials through social engineering — a threat pattern well-documented in cloud and hybrid enterprise environments. With those credentials attackers traversed the environment without encountering meaningful lateral movement controls, exfiltrated the Windows domain controller's NTDS.dit file, elevated privileges, and deployed DragonForce ransomware across M&S's VMware ESXi estate on April 24, 2025 [6].

- **(August 2025)** OAuth Supply Chain Attack — UNC6395 via Drift-Salesforce Integration: In August 2025, threat actor UNC6395 exploited stolen OAuth tokens from Drift's Salesforce integration to access customer environments across more than 700 organisations. The attack required no exploit code and no phishing — the activity presented as entirely legitimate because it originated from a trusted SaaS-to-SaaS connection, rather than a recognisably compromised user account. Access was granted through a trust relationship that client organisations had established, never reviewed, and had no capability to monitor [4].
- **(2026)** Netskope's 2026 report states that personal account usage among AI users fell from 78% to 47%, while organization-managed account usage rose from 25% to 62%. That nuance is useful: the trend is improving, but almost half of GenAI users still use personal AI applications, which remains a material governance issue [8].
- **(2024)** IBM's Cost of a Data Breach Report 2024 reported a global average breach cost of \$4.88 million USD, with financial-sector organizations averaging \$6.08 million USD per incident. IBM's 2025 reporting later placed the global average breach cost at \$4.44 million USD and highlighted the additional cost impact of shadow AI, with incidents involving shadow AI adding approximately \$670,000 USD to average breach cost. These findings demonstrate the financial impact of unresolved cloud and AI governance gaps. Where cloud security strategy is lacking undocumented assets, unmapped integrations, unreviewed access, unmanaged AI usage, and weak credential governance can extend containment timelines, increase investigation complexity, and increase recovery costs. Strategic investment in cloud security governance reduces these variables by improving visibility, ownership, control validation, and response readiness across cloud, SaaS, and AI environments [2, 3, 5, 6, 9].

CSA CBK SECURITY GUIDANCE VERSION 5.0

Domain 2: Cloud Governance

Domain 3: Risk, Audit, & Compliance

Domain 4: Organization Management

Domain 5: Identity & Access Management

Domain 6: Security Monitoring

Domain 8: Cloud Workload Security

Domain 9: Data Security

Domain 10: Application Security

Domain 11: Incident Response & Resilience

Domain 12: Related Technologies & Strategies

CSA AICM CONTROLS VERSION 1.1

AIS Application and Interface Security

AIS-01: Application & Interface Security Policy & Procedures
AIS-02: Application Security Baseline Requirements
AIS-03: Application Security Metrics
AIS-11: Agent Security Boundaries

DSP Data Security & Privacy Lifecycle Management

DSP-03: Data Inventory
DSP-04: Data Classification
DSP-07: Data Protection by Design and Default
DSP-17: Sensitive Data Protection
DSP-19: Data Location

LOG Logging and Monitoring

LOG-03: Security Monitoring and Alerting
LOG-05: Audit Logs Monitoring and Response
LOG-07: Logging Scope

GRC Governance, Risk & Compliance

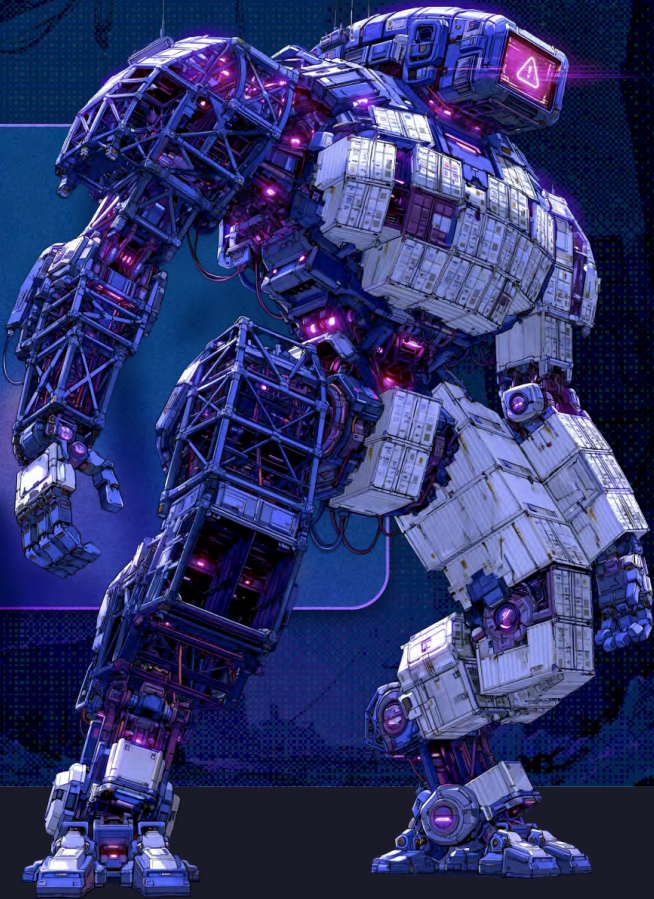
GRC-01: Governance Policy and Procedures
GRC-03: Roles and Responsibilities
GRC-06: Risk Management Program

CCC Change Control and Configuration Management

CCC-07: Detection of Baseline Deviation
CCC-08: Exception Management

Reference Links

1. Cloud Security Alliance and Google Cloud. "The State of AI Security and Governance Survey Report." December 18, 2025.
cloudsecurityalliance.org/press-releases/2025/12/18/csa-and-google-cloud-study-finds-governance-maturity-is-strongest-predictor-of-ai-readiness
2. IBM. "Cost of a Data Breach Report 2025." August 2025.
www.ibm.com/reports/data-breach
3. Cloud Security Alliance. "The State of Cloud and AI Security in 2026." March 13, 2026.
cloudsecurityalliance.org/blog/2026/03/13/the-state-of-cloud-and-ai-security-in-2026
4. Reco AI. "AI & Cloud Security Breaches: 2025 Year in Review." March 6, 2026.
www.reco.ai/blog/ai-and-cloud-security-breaches-2025
5. Office of the Comptroller of the Currency. "OCC Assesses \$80 Million Civil Money Penalty Against Capital One." August 6, 2020.
[www.occ.gov/news-issuances/news-releases/2020/nr-occ-2020-98.html](https://www OCC.gov/news-issuances/news-releases/2020/nr-occ-2020-98.html)
6. Specops Software / Darktrace. "How Scattered Spider Compromised Marks & Spencer." 2025.
specopssoft.com/blog/marks-spencer-ransomware-active-directory
7. Darktrace. "Untangling the Web: Darktrace's Investigation of Scattered Spiders' Evolving Tactics." July 24, 2025.
www.darktrace.com/blog/untangling-the-web-darktraces-investigation-of-scattered-spiders-evolving-tactics
8. CISA. "CISA Releases Guidance on Credential Risks Associated with Potential Legacy Oracle Cloud Compromise." April 16, 2025.
www.cisa.gov/news-events/alerts/2025/04/16/cisa-releases-guidance-credential-risks-associated-potential-legacy-oracle-cloud-compromise
9. Netskope / Cybersecurity Dive. "Risky Shadow AI Use Remains Widespread." January 6, 2026.
www.cybersecuritydive.com/news/shadow-ai-security-risks-netkope/808860



SECURITY ISSUE 09

Insecure Software Development

Software development in cloud environments introduces a unique class of security risks where application-layer weaknesses can directly lead to cloud compromise. Insecure software development refers to implementation weaknesses and design flaws in code, dependencies, CI/CD pipelines, or integration design — which exposes credentials, tokens, or over-privileged cloud identities, enabling attackers to access cloud control planes and SaaS platforms.

These security risks commonly arise from well-understood development challenges, including insecure coding practices, improper dependency management, overprivileged automation identities, and weak secret handling. In cloud-first environments these issues are amplified by automation as CI/CD pipelines propagate insecure configurations and code across development, test, and production, turning isolated weaknesses into systemic exposure. Insecure development practices have repercussions across multiple layers of the cloud stack, including application code, third-party dependencies, CI/CD pipelines, secret storage, and IAM roles assigned to workloads and automation systems. Because these components operate with trusted access to cloud environments, their compromise often directly leads to access to cloud resources.

Cloud providers expose rich sets of native security controls — including identity and access management, detection, infrastructure protection, data protection, incident response, and application security [1], but these controls require explicit configuration and integration into development workflows and IaC practices to be effective. Embedding these controls into the SDLC is essential to achieve secure-by-default architectures; without this, they remain underutilized, leaving development-driven attack paths unaddressed.

Organizations must also clearly understand the shared responsibility model. Cloud providers are responsible for securing and patching the underlying infrastructure and managed services while

customers are responsible for securing and patching their applications, dependencies, and CI/CD pipelines [2]. Misunderstanding this boundary often creates gaps attackers can exploit.

TECHNICAL IMPACT

Confidentiality

- *Disclosure of Cloud Credentials and Sensitive Data:* Insecure software development practices, including hardcoded secrets, vulnerable dependencies, exposed CI/CD pipelines, and improperly secured integrations, may enable attackers to obtain cloud credentials and sensitive data. This can result in unauthorized access to sensitive data stored in cloud services, SaaS platforms, source code repositories, and development systems.

Integrity

- *Unauthorized Modification of Cloud Resources and Software Artifacts:* Compromised applications may enable attackers to alter cloud resources, tamper with deployment artifacts, inject malicious code into software supply chains, or modify IaC configurations.

Availability

- *Disruption of Cloud Services and Development Operations:* Insecure development practices may lead to compromised pipelines, abused cloud identities, or malicious changes. These can disrupt application deployments, disable cloud resources, corrupt environments, or trigger outages across cloud-hosted services and development platforms.

BUSINESS IMPACT

Operational

- *Release Disruption:* Security issues in code or pipelines force emergency fixes, delaying deployments and disrupting delivery cycles.
- *Environment Recovery Effort:* Credential leaks require secret rotation, environment rebuilds, and pipeline re-hardening.

Financial

- *Cloud Resource Abuse:* Stolen credentials can be used for large-scale compute or storage usage, leading to unexpected costs.

Compliance

- *Regulatory Violations:* Insecure software development practices may enable unauthorized access to regulated cloud and SaaS environments, potentially resulting in violations of data protection, privacy, cybersecurity, or industry-specific regulatory requirements.

Reputational

- *Loss of Trust:* Breaches tied to insecure development practices undermine confidence in the organization's ability to secure cloud environments.

KEY TAKEAWAYS

- **Make SDLC explicitly cloud-aware:** Define and implement a Secure Development Lifecycle (SDLC) that covers not only application code but also dependencies, CI/CD pipelines, secrets management, and IAM design for workloads and automation identities.
- **Treat CI/CD and dev tooling as cloud-critical infrastructure:** Harden build systems, code-scanning tools, dependency scanners, and IDE integrations with least-privilege roles, short-lived credentials, strong provenance/signing, and monitoring, so a tool compromise does not become a cloud account compromise.
- **Eliminate hard-coded secrets:** Replace hard-coded credentials and long-lived keys with cloud-native secret stores, federated identities (OIDC), and short-lived tokens to reduce the blast radius when development or CI environments are breached.
- **Apply the shared responsibility model:** Clearly define ownership boundaries between CSP-managed services and customer-managed applications, dependencies, and CI/CD pipelines.
- **Use CSP-provided security frameworks and reference architectures instead of reinventing controls:** Leverage established guidance such as the Google Cloud Well-Architected Framework: Security, privacy, and compliance pillar [3] and reference architectures like the AWS Security Reference Architecture (AWS SRA) [4], and other similar secure design patterns from CSPs to align development practices with proven cloud security baselines.

ANECDOTES AND EXAMPLES

Recent issues related to insecure software development that have impacted cloud computing environments include:

- **(March 2025)** EC2 SSRF Campaign Against AWS IMDS: In 2025, researchers documented campaigns that probed Internet-facing EC2 applications for Server-Side Request Forgery (SSRF) paths to the AWS Instance Metadata Service, particularly IMDSv1. Where applications accepted unvalidated URLs and EC2 instances still exposed IMDSv1, attackers could fetch instance-role credentials and then call AWS APIs using that role, turning a web application bug into direct access to cloud resources such as S3 and EC2. This pattern shows how insecure application development and failure to harden metadata access can elevate an SSRF flaw into a full cloud IAM compromise [5].
- **(August 2025)** Azure OpenAI critical SSRF vulnerability: In August 2025, Microsoft patched a critical SSRF vulnerability (CVSS 10.0, maximum severity) in Azure OpenAI. The flaw enabled unauthenticated attackers to access Azure IMDS, retrieve managed identity tokens, and potentially cross tenant boundaries. This vulnerability highlights how even cloud-native AI services can expose metadata endpoints due to insufficient input validation. Cloud security requires a defense-in-depth approach, with multiple layers of protection for metadata services [6].
- **(September 2025)** Pandoc SSRF and AWS Metadata Credential Theft Risk: In 2025, Wiz reported active exploitation attempts targeting an SSRF vulnerability in Pandoc [7], which

could be triggered by crafted HTML with iframes. When applications processed untrusted documents with Pandoc on EC2 instances which still allowed IMDSv1, attackers could coerce the service to request 169.254.169.254 and leak IAM role credentials from the metadata service. This incident highlights how insecure use of third-party libraries in server-side rendering pipelines, combined with cloud-unsafe defaults, could lead to a parsing bug that granted AWS control-plane access [8].

- **(April 2026)** Vercel OAuth Supply Chain and Environment Variable Exposure: In April 2026, Vercel disclosed a breach in which attackers pivoted from a compromised Context.ai Google Workspace OAuth app into a Vercel employee account, and then into Vercel's internal environment. There they enumerated 'non-sensitive' environment variables which remained fully readable because Vercel treated them as ordinary configuration unless developers explicitly flagged them as sensitive. Many teams had stored cloud provider credentials (including AWS keys) in these 'non-sensitive' variables, making them directly accessible and enabling potential downstream compromise of customer cloud and SaaS resources. This incident illustrates how insecure software development practices, using environment variables as a general secrets store and relying on opt-in protections instead of secure-by-default handling, can turn an OAuth identity compromise into broad cloud credential exposure [9] [10].

CSA CBK SECURITY GUIDANCE VERSION 5.0

Domain 1: Cloud Computing Concepts and Architecture

Domain 5: Identity & Access Management

Domain 10: Application Security

Domain 11: Incident Response & Resilience

CSA AICM CONTROLS VERSION 1.1

AIS Application and Interface Security

AIS-04: Secure Application Development Lifecycle

AIS-05: Application Security Testing

AIS-06: Secure Application Deployment

AIS-07: Application Vulnerability Remediation

AIS-09: Input Validation

CCC Change Control and Configuration Management

CCC-02: Quality Testing

IAM Identity & Access Management

IAM-01: Identity & Access Management Policy & Procedures

IAM-04: Segregation of Duties

IAM-05: Least Privilege

IAM-14: Strong Authentication

IAM-16: Authorization Mechanisms

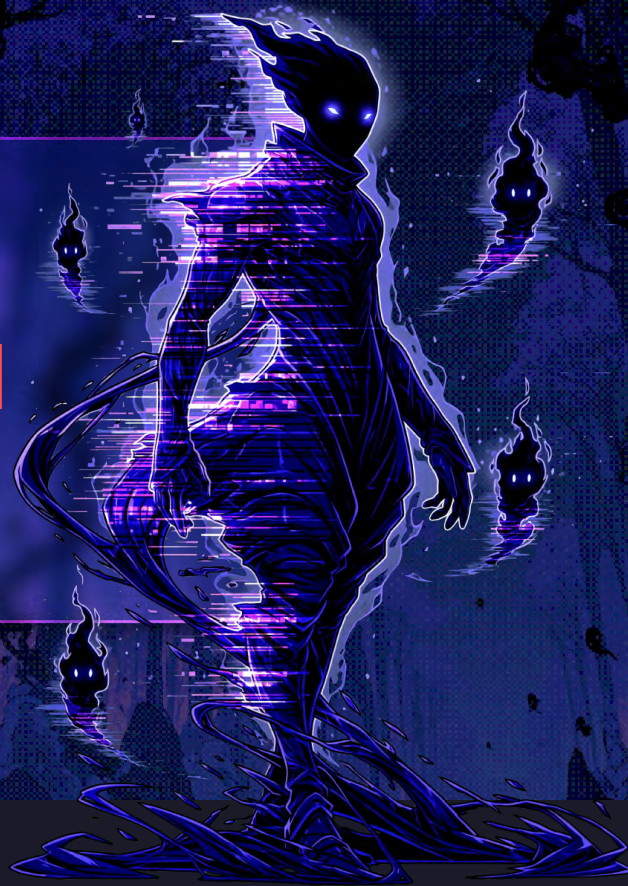
TVM Threat & Vulnerability Management

TVM-03: Vulnerability Remediation Schedule

Reference Links

1. Security Pillar - AWS Well-Architected Framework
docs.aws.amazon.com/wellarchitected/latest/security-pillar/welcome.html
2. Shared responsibility
docs.aws.amazon.com/wellarchitected/latest/security-pillar/shared-responsibility.html
3. Well-Architected Framework: Security, privacy, and compliance pillar
docs.cloud.google.com/architecture/framework/security
4. AWS Security Reference Architecture (AWS SRA) – core architecture
docs.aws.amazon.com/prescriptive-guidance/latest/security-reference-architecture/introduction.html
5. Campaign Targets Amazon EC2 Instance Metadata via SSRF -
www.f5.com/labs/articles/campaign-targets-amazon-ec2-instance-metadata-via-ssrf
6. CVE-2025-53767 Detail
nvd.nist.gov/vuln/detail/CVE-2025-53767
7. CVE-2025-51591 Detail
www.cve.org/CVERecord?id=CVE-2025-51591
8. Hackers Exploit Pandoc CVE-2025-51591 to Target AWS IMDS and Steal EC2 IAM Credentials -
thehackernews.com/2025/09/hackers-exploit-pandoc-cve-2025-51591.html
9. Vercel April 2026 security incident
vercel.com/kb/bulletin/vercel-april-2026-security-incident
10. Vercel April 2026 Incident: Non-Sensitive Environment Variables Need Investigation Too
blog.gitguardian.com/vercel-april-2026-incident-non-sensitive-environment-variables-need-investigation-too/

Accidental Cloud Data Exposure



The risk of accidental data disclosure continues to plague cloud services. Accidental cloud data exposure commonly results from misconfiguration, excessive permissions, weak access governance, insecure software deployment practices, or unauthorized use of cloud and AI services. Data Stack Hub's Cloud Vulnerability Statistics for 2025-2026 noted these misconfiguration issues [1]:

- 45% of cloud databases were publicly accessible due to insufficient access controls or misconfigured settings. In addition
- 29% of cloud systems had one or more assets that are exposed and vulnerable, and that contain privileged information.
- 54% of cloud environments contained hard-coded credentials in configuration files or containers.
- More than 30% of developers admitted to accidentally committing credentials to public cloud system repositories.

Accidental exposure is not limited to cloud infrastructure. AI systems present equally significant — and in some ways more subtle — risks of unintended data disclosure. Shadow AI is a fast-growing accidental data exposure trend. One type of Shadow AI occurs when employees use AI tools and services without approval from the organization's IT or security teams. Examples include pasting sensitive work data into public chatbots through prompts or using unauthorized AI-powered apps. The risk of data exposure is heightened since AI tools actively process and potentially retain submitted data, often outside corporate data governance and security controls [2]. Recent security research reveals the growing scope of Shadow AI risk.

- According to a 2025 IDC study, 56% of employees surveyed use unauthorized AI tools at work. Only 23% use AI tools approved and administered by their companies [2].
- Research by Lasso Security found that 13% of employee-submitted prompts to AI chat systems contained sensitive company data [3].

A second Shadow AI modality involves AI models or applications deployed without formal security assessment or governance oversight. According to IBM's Cost of a Data Breach Report 2025, unauthorized AI use accounted for approximately 20% of AI-related breaches that year — and among organizations that experienced such incidents, 97% lacked proper AI access controls [4].

MCP (Model Context Protocol) servers which connect AI systems with external tools, data resources, and other systems — have become an important integration layer across enterprise environments. An MCP server can enable an AI agent to read and write files, query databases, search and retrieve data from code repositories, and take any number of other actions on systems. Left unsecured, MCP servers provide a data exposure surface that leaves systems open to unauthorized access.

Security researchers at TrendAI found the MCP security landscape is not improving. In 2025 they scanned for and found 492 MCP servers with no client authentication or traffic encryption [5]. By 2026, the researchers discovered 1,497 exposed MCP servers — nearly three times the number from the previous year [6].

TECHNICAL IMPACT

Confidentiality

- *Data Disclosure:* When sensitive company or personal data is exposed due to misconfiguration or other errors, it can be accessed by unauthorized users.
- *Source Code Disclosure:* Proprietary source code that is exfiltrated or made publicly accessible is exposed to unauthorized parties, which can diminish a company's competitive advantage.
- *Weakened Security:* Failure to close security gaps, such as misconfigured data stores lacking IAM controls, leaves critical data exposed to unauthorized users.

Integrity

- *Destruction or Corruption of Data:* Improperly controlled changes or misconfigured workflows may corrupt or destroy datasets, model artifacts, or critical system data, affecting system integrity or recoverability.
- *AI Resource Exposure:* Unsecured LLM code can give attackers visibility into guardrails, internal tooling, memory systems, and unlaunched features.

Availability

- *Loss of Data:* Exposed data can be corrupted or erased, severely degrading cloud service operations. Affected systems, APIs, or storage buckets may be taken offline for investigation and containment.
- *System Disruption:* Depending on the scope of data loss, cloud service operation can be partially degraded or completely shut down while a service is being recovered.

BUSINESS IMPACT

Operational

- *Business Disruption:* Attackers can find and compromise unsecured storage and containers, disrupting normal system operations.

Financial

- *Non-compliance:* The California Consumer Privacy Act (CCPA) and General Data Protection Regulation (GDPR) provide hefty fines for breaches.
- *Lost Revenue:* Recovery from data corruption or loss significantly increases operational costs and results in diminished profits. Customers who have lost confidence in cloud services which appear prone to data exposure stop using and paying for those services

Compliance

- *Regulatory Violations:* Misconfigured cloud or AI environments may violate data protection, privacy, cybersecurity, or industry-specific regulatory requirements.

Reputational

- *Company Reputation:* Publicity from breaches can negatively affect consumer and business perceptions of a company's integrity and its ability to govern, control, and manage the business.
- *Customer Confidence:* Customers may be reluctant to use cloud services that cannot guarantee the security and integrity of their data.

KEY TAKEAWAYS

- Follow the best practices discussed in the Security Issue 01: Inadequate Identity and Access Management and Security Issue 05: Misconfiguration and Inadequate Change Control sections of this publication, specifically:
 - Enforce Least Privilege to Limit Impact Scope: Ensure entities have only the access rights needed to perform their tasks.
 - Prevent unauthorized exposure of cloud and AI services: Cloud resources, AI services, storage repositories, inference endpoints, vector databases, and management interfaces must not be deployed or left publicly accessible without authentication and appropriate access controls.
 - Secure sensitive data, credentials, and logs by default: Training data, embeddings, model artifacts, credentials, and logs should all be treated as sensitive assets. Logging, debugging, and analytics systems are all common sources of exposure.
- To further reduce risk, organizations should consider these safeguards [7][8]:
 - Deploy Data Loss Prevention (DLP) solutions: Monitor company data at rest and in motion. Block unauthorized exfiltration of sensitive data.
 - Deploy Discovery Tools: Monitor cloud and AI usage to identify unauthorized usage.

- **Conduct Comprehensive Data Inventory and Classification:** Identify and classify data based on sensitivity to and business value for the company. Know where sensitive data is securely stored and, when necessary, how to dispose of it securely.
- **Establish Access Policies for Cloud and AI Tools:** Create access policies with tiered classifications: approved, restricted, and prohibited.
- **Conduct Regular Privacy and Security Audits:** Perform periodic assessment of data protection measures to ensure they provide adequate protection.
- **Train Employees on Data Security Awareness:** Inform employees about AI usage policies and how to avoid Shadow AI. Provide training on recognizing and mitigating phishing attacks, as well as proper methods for securely handling sensitive data.

ANECDOTES AND EXAMPLES

Recent examples of accidental cloud data disclosure issues include:

- **(Feb 2025)** Israeli cybersecurity firm Lasso discovered that data briefly exposed on GitHub doesn't truly disappear when repositories are made private — it can persist indefinitely inside Microsoft Copilot. Lasso's broader investigation found over 20,000 private GitHub repositories still accessible through Copilot, affecting more than 16,000 organizations — including AWS, Google, IBM, PayPal, Tencent, and Microsoft itself. In some cases, the exposed content included intellectual property, credentials, and access tokens. Lasso also used Copilot to retrieve a deleted Microsoft repository that had hosted a tool for generating harmful AI images [9].
- **(Oct 2025)** A publicly readable S3 bucket exposed hundreds of thousands of sensitive bank transfer authorization PDFs. The files included customer names, home addresses, phone numbers, email addresses, bank account numbers, and IFSC routing codes. New files continued to appear in the bucket while researchers were analyzing it, indicating the bucket was actively in use — not merely an abandoned test resource. No advanced techniques were required — the bucket simply allowed public read access [10].
- **(Feb 2026)** Security researchers at Wiz discovered a critical database misconfiguration in Moltbook — the viral "social network for AI agents" where over 1.5 million autonomous AI agents post, comment, and coordinate. The database was configured with public read access and no row-level security policies — exposing 1.5 million API keys stored in plaintext for OpenAI, Anthropic, AWS, GitHub, and Google Cloud, plus 35,000 user emails [11].
- **(March 2026)** Security researcher Chaofan Shou discovered on March 31, 2026, that Anthropic's Claude Code CLI tool had its full TypeScript source code sitting in plain sight on the publicly available npm registry. Version 2.1.88 of the @anthropic-ai/claude-code package shipped with a source map file that should never have been included. The root cause was a single misconfigured .npmignore file. A release team member failed to add *.map to the project's .npmignore file and the files field in package.json was not configured to exclude debug artifacts. The build tool Anthropic used — Bun — generates full source maps by default, and nobody caught the omission before it was published to the public registry. The leaked file contained approximately 513,000 lines of unobfuscated TypeScript across 1,906 files, revealing the complete client-side agent harness [12].

CSA CBK SECURITY GUIDANCE VERSION 5.0

Domain 2: Cloud Governance
Domain 5: Identity & Access Management
Domain 7: Infrastructure & Networking
Domain 9: Data Security
Domain 10: Application Security

CSA AICM CONTROLS VERSION 1.1

AIS Application and Interface Security

AIS-02: Application Security Baseline Requirements
AIS-04: Secure Application Development Lifecycle

BCR Business Continuity Mgt & Op. Resilience

BCR-05: Documentation

DSP Data Security & Privacy Lifecycle Mgt

DSP-01: Security and Privacy Policy and Procedures
DSP-02: Secure Disposal
DSP-03: Data Inventory
DSP-06: Data Ownership and Stewardship
DSP-10: Sensitive Data Transfer

GRC Governance, Risk Mgt, and Compliance

GRC-01: Governance Program Policy and Procedures
GRC-02: Risk Management Program

IAM Identity and Access Management

IAM-01: Identity & Access Mgt Policy & Procedures
IAM-03: Identity Inventory
IAM-05: Least Privilege

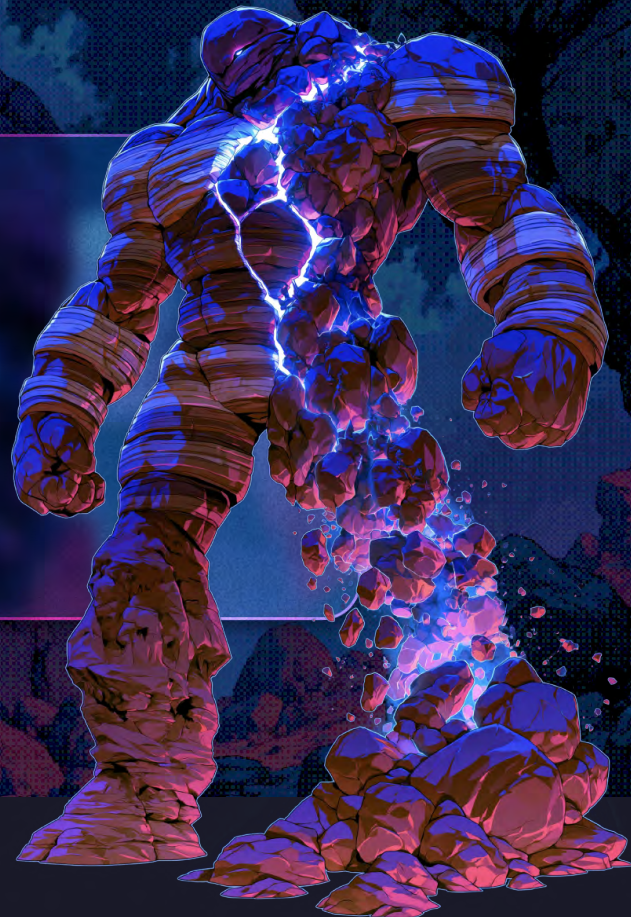
I&S Infrastructure Security

I&S-01: Infrastructure and Virtualization Security Policy and Procedures
I&S-03: Network Security
I&S-06: Segmentation And Segregation

Reference Links

1. Cloud Vulnerability Statistics for 2025–2026 – Exposure, Exploits & Risk Trends
www.datastackhub.com/insights/cloud-vulnerability-statistics/
2. What Is Shadow AI? Definition, Risks & Governance Strategies
www.sentinelone.com/cybersecurity-101/cybersecurity/what-is-shadow-ai/
3. Lasso Research Reveals 13% of Generative AI Prompts Contain Sensitive Organizational Data
lasso.security/blog/lasso-research-reveals-13-of-generative-ai-prompts-contain-sensitive-organizational-data
4. Cost of a Data Breach Report 2025
www.ibm.com/reports/data-breach
5. MCP Security: Network-Exposed Servers Are Backdoors to Your Private Data
www.trendaisecurity.com/en-us/resources-insights/research/mcp-security-network-exposed-servers-are-backdoors-to-your-private-data
6. Update on Exposed MCP Servers - The Threat Widens to the Cloud
www.trendmicro.com/vinfo/us/security/news/vulnerabilities-and-exploits/update-on-exposed-mcp-servers-the-threat-widens-to-the-cloud
7. Top 15 Data Protection Best Practices 2025
www.datastackhub.com/best-practices/data-protection-best-practices/
8. Top AI Security Vulnerabilities to Watch out for in 2026
cycode.com/blog/ai-security-vulnerabilities/
9. Thousands of exposed GitHub repositories, now private, can still be accessed through Copilot
techcrunch.com/2025/02/26/thousands-of-exposed-github-repositories-now-private-can-still-be-accessed-through-copilot/
10. S3 Bucket — 273K Bank Transfer PDFs Left Publicly Readable
cloudstoragesecurity.com/news/anatomy-of-an-s3-exposure-273k-bank-transfer-pdfs-left-open-online
11. INCIDENT BRIEF: Moltbook Breach Exposes 1.5 Million AI Agent API Keys
www.prplbx.com/blog/moltbook-breach-incident-brief
12. Anthropic Source Code Leak Unleashes Massive Chaos
www.brightdefense.com/news/claude-source-code-leak/

System Vulnerabilities



Cloud service system vulnerabilities are weaknesses in cloud infrastructure, configuration, or design that can be exploited to compromise confidentiality, integrity, or availability of data and services. A cloud service stack is composed of discrete layers: application, platform, infrastructure, and datacenter — each with its own attack surface [1][2]. Vulnerabilities rarely stay contained. A weakness at one layer can cascade upward or downward, compromising the entire stack.

Four common types of cloud system vulnerabilities are [3]:

1. **Misconfiguration:** One of the largest threats to cloud and app security. Many applications and security tools still require manual configuration, which is prone to human error. Over 31% of cloud breaches are caused by misconfiguration and manual errors [4]. See the Security Issue 05: Misconfiguration and Inadequate Change Control section of this publication for more information.
2. **Outdated or Unpatched Software:** Software containing known security weaknesses that have not been fixed despite the availability of patches. 91% of organizations harbor security flaws older than 10 years, while 46% operate with vulnerabilities over 20 years old [4].
3. **Zero-day Vulnerabilities:** These are vulnerabilities discovered and exploited by threat actors before cloud service providers and software vendors are aware of them.
4. **Weak or Stolen Credentials:** Lack of strong authentication increases the likelihood of threat actors gaining unauthorized access to sensitive data and systems. Stolen credentials are as dangerous as weak credentials. See the Security Issue 01: Inadequate Identity and Access Management section of this publication for a more detailed discussion of IAM issues and best practices.

A cloud-centric view of system vulnerabilities must also account for the speed and scale at which exposed weaknesses can be discovered and operationalized. In cloud environments a single flaw is rarely isolated to one workload — it can become a path to control-plane access, lateral movement across services, or exposure of shared assets when identities, APIs, and automation layers are tightly interconnected. This makes vulnerability management inseparable from asset inventory, exposure management, and continuous verification.

Many of these cloud risks are compounded when AI workloads enter the picture — bringing with them a new layer of vulnerabilities specific to model behavior, data pipelines, and inference infrastructure. AI systems are susceptible to data poisoning where attackers modify model parameters or architecture with malicious intent, creating potential hidden backdoors or modifying model behavior in unexpected, unnoticeable ways [5].

RAG poisoning has emerged as a critical attack vector in 2026. In a RAG pipeline, an LLM retrieves semantically similar documents from an external datastore to incorporate into responses. Adversaries exploit this architecture by injecting malicious content into that datastore, effectively corrupting the retrieval pool from which the model draws [6]. Security researcher Amine Raji demonstrated how potent and straightforward a RAG attack can be. Raji built a proof of concept that injected three documents with domain-specific financial terminology into a vector database that caused an LLM to report false financial data (\$8.3M USD revenue vs. the real \$24.7M USD figure) with a 95% success rate. The technique did not require exploits or malicious payloads, just vocabulary engineering to craft bogus documents to look like relevant financial data [7].

Beyond the retrieval layer, adversaries target the inference layer itself. Prompt injection attacks manipulate the instructions supplied to the model directly, bypassing retrieval entirely, to subvert LLM behavior at runtime. Attackers craft inputs that cause LLMs to ignore original instructions. Since models act on system prompts and user inputs in a single text stream, differentiating between the two is nearly impossible [8].

TECHNICAL IMPACT

Confidentiality

- *Data Disclosure:* Sensitive and mission-critical data can be more easily stolen from or exposed in systems that have unpatched vulnerabilities.

Integrity

- *Weakened Security:* Cloud services that fail to address system vulnerabilities are more susceptible to attack and compromise.
- *Destruction or Corruption of Data:* Improperly controlled changes or misconfigured workflows may corrupt or destroy datasets, model artifacts, or critical system data — affecting system integrity or recoverability.

Availability

- *System Availability:* Compromised cloud services can be taken offline for extended periods, preventing customers from using them.
- *Loss of Data:* Additionally, compromised cloud services can result in accidental deletion, unavailability of critical cloud or AI data, degraded performance, or outages of cloud or AI services.

BUSINESS IMPACT

Operational

- *Business Disruption*: Data loss can prevent organizations from fulfilling business obligations to partners and customers.
- *System Performance*: Cloud services under attack can experience degraded performance and even outages.

Financial

- *Non-compliance and Fines*: Failure to adhere to regulatory requirements for vulnerability management and associated penalties.
- *Lost Revenue*: Financial losses due to service disruptions, restoration, customer dissatisfaction, or legal action.

Compliance

- *Regulatory Violations*: Cloud or AI environments with unpatched vulnerabilities may violate data protection, privacy, cybersecurity, or industry-specific regulatory requirements.
- *Policy or Guideline Non-conformance*: Lack of vulnerability management may violate internal security policies, governance requirements, or contractual obligations.

Reputational

- *Cloud Service Provider (CSP)*: Damage to the cloud service organization's public image and brand value.
- *CSP Customer Reputation*: Clients relying on compromised third-party cloud services may experience data breaches and service interruptions, which can negatively impact their reputations.

KEY TAKEAWAYS

- **Conduct regular vulnerability scans**: Periodic scanning for known vulnerabilities in operating systems, networking, and application software enables security to identify issues that can compromise cloud service integrity and operation [9].
- **Conduct regular patch management**: Apply patches or fixes as soon as they are identified during vulnerability scans and are reported by software vendors to address known security vulnerabilities in software, operating systems, and infrastructure [9].
- **Integrate patching into release cycles**: Scanning for and patching vulnerabilities in software during development and prior to release helps reduce software vulnerability risk and strengthen customer confidence [9].
- **Classify assets and prioritize risks**: Not all vulnerabilities present the same degree of risk. Similarly, cloud systems vary in their business value to an organization. Since IT resources are frequently constrained by time and availability, companies should identify the most business-critical assets and the highest-risk vulnerabilities. Cloud threat modeling methodologies and technologies can facilitate this process [9] [10].

- **Employ continuous monitoring and threat intelligence:** Scanning systems in real time provides immediate information on what is happening in a network, users' actions, and logs — alerting security teams to newly introduced malware activity. Combining monitoring with external threat intelligence can help identify zero-day vulnerabilities in a company's cloud services [6][8].
- **Conduct periodic penetration testing:** In addition to the scanning and monitoring discussed so far, penetration testing can reveal vulnerabilities that other techniques miss. Pen testing can reveal how systems respond to real-world attacks, enabling security teams to fix vulnerabilities before threat actors exploit them [9].

ANECDOTES AND EXAMPLES

Recent examples of issues related to system vulnerabilities in the cloud include:

- **(October 2025)** Threat actors exploited an Oracle Database vulnerability (CVE-2025-61882) at The Washington Post to steal personal information on 9,720 people — including names, bank account numbers and routing numbers, and Social Security numbers [11] [12].
- **(Aug 2025)** CVE-2025-53773 is a critical vulnerability in GitHub Copilot and Visual Studio Code that allows attackers to achieve remote code execution through prompt injection, potentially leading to full system compromise of developers' machines. The attack embeds malicious instructions in source code files, web pages, or GitHub issues — sometimes using invisible Unicode characters to evade detection. Once processed, Copilot modifies the settings file to enable auto-approval mode, escalating privileges without user consent [13] [14].
- **(February/March 2026)** Threat actor FulcrumSec exploited a known, unpatched vulnerability ("React2Shell": CVE-2025-55182) in a LexisNexis frontend application to gain entry to their AWS environment. Overpermissioned IAM roles then allowed lateral movement from the frontend container into production databases and AWS Secrets Manager, where 53 credentials were stored in plaintext. The breach exposed 3.9 million database records, including data belonging to federal judges, DOJ attorneys, and SEC staff [15][16].
- **(March 2026)** A group called TeamPCP used compromised credentials to publish a malicious release of Trivy (a security scanner), v0.69.4 (CVE-2026-33634). Trivy is an open-source vulnerability scanner maintained by Aqua Security with more than 100,000 users and contributors, embedded in thousands of CI/CD pipelines across numerous companies [17] [18].

CSA CBK SECURITY GUIDANCE VERSION 5.0

Domain 5: Identity & Access Management

Domain 6: Security Monitoring

Domain 7: Infrastructure & Networking

Domain 9: Data Security

Domain 10: Application Security

Domain 11: Incident Response & Resilience

CSA AICM CONTROLS VERSION 1.1

AIS Application and Interface Security

AIS-01: Application & Interface Security Policy & Procedures

AIS-02: Application Security Baseline Requirements

AIS-04: Secure Application Development Lifecycle

AIS-07: Application Vulnerability Remediation

IAM Identity and Access Management

IAM-01: Identity and Access Management Policy and Procedures

IAM-02: Credentials Management Policy and Procedures

IAM-13: Strong Authentication

IAM-14: Credentials Management

IAM-15: Authorization Mechanisms

CEK Cryptography, Encryption & Key Mgt

CEK-03: Data Protection

CEK-04: Encryption Algorithm

I&S Infrastructure Security

I&S-04: OS Hardening and Base Controls

TVM Threat & Vulnerability Management

TVM-01: Threat and Vulnerability Management Policy and Procedures

TVM-02: Malware Protection Policy and Procedures

TVM-03: Vulnerability Remediation Schedule

TVM-04: Detection Updates

TVM-06: Penetration Testing

Reference Links

1. A Deep Dive into Layered Architecture of Cloud Computing
docsallover.com/blog/cloud-computing/a-deep-dive-into-layered-architecture/
2. Layered Architecture of Cloud
www.geeksforgeeks.org/devops/layered-architecture-of-cloud/
3. Most Common Types of Cyber Vulnerabilities
www.crowdstrike.com/en-us/cybersecurity-101/exposure-management/cyber-vulnerabilities/
4. 50+ Cloud Security Statistics in 2026
www.sentinelone.com/cybersecurity-101/cloud-security/cloud-security-statistics/
5. Top 14 AI Security Risks in 2026
www.sentinelone.com/cybersecurity-101/data-and-ai/ai-security-risks/
6. The Biggest AI Security Vulnerabilities Discovered in 2026
www.redfoxsec.com/blog/the-biggest-ai-security-vulnerabilities-discovered-in-2026-redfox-cybersecurity
7. Three Documents Were Enough: A RAG Poisoning Attack With a 95% Success Rate
agent-wars.com/news/2026-03-12-document-poisoning-in-rag-systems-how-attackers-corrupt-ai-s-sources
8. Top AI Security Vulnerabilities to Watch out for in 2026
cycode.com/blog/ai-security-vulnerabilities/
9. 10 Vulnerability Management Best Practices
www.sentinelone.com/cybersecurity-101/cybersecurity/vulnerability-management-best-practices/
10. CSA Cloud Threat Modeling 2025
cloudsecurityalliance.org/artifacts/cloud-threat-modeling-2025
11. Washington Post confirms data on nearly 10,000 people stolen from its Oracle environment
cyberscoop.com/washington-post-oracle-clop-attacks/

12. CVE-2025-61882- Vulnerability in the Oracle Concurrent Processing product of Oracle E-Business Suite
www.cve.org/CVERecord?id=CVE-2025-61882
13. CVE-2025-53773: Visual Studio 2022 vulnerability analysis and mitigation
www.wiz.io/vulnerability-database/cve/cve-2025-53773
14. GitHub Copilot and Visual Studio Remote Code Execution Vulnerability
www.cve.org/CVERecord?id=CVE-2025-53773
15. LexisNexis Data Breach — Threat Actor Allegedly Claims 2.04 GB Stolen
cybersecuritynews.com/lexisnexis-data-breach/
16. CVE-2025-55182 - React Server pre-authentication remote code execution
www.cve.org/CVERecord?id=CVE-2025-55182
17. Two different attackers poisoned popular open source tools - and showed us the future of supply chain compromise
www.theregister.com/2026/04/11/trivy_axios_supply_chain_attacks/
18. CVE-2026-33634 - Trivy ecosystem supply chain briefly compromised
www.cve.org/CVERecord?id=CVE-2026-33634

Conclusion and Future Outlook

The 2026 survey results tell a consistent story: the boundaries between cloud security and AI security are collapsing. Misconfiguration, identity weaknesses, insecure APIs, supply chain dependencies, and governance failures have not gone away, but AI is now embedded throughout the cloud stack, in applications, pipelines, operational tooling, and the attacks targeting them all. The introduction of AI-Driven Attacks and AI System Compromise as discrete threat categories is not an approaching trend to watch. It is already the present condition.

A common thread running through most of the Top Threats is complexity outpacing governance. Organizations depend on interconnected networks of cloud services, AI systems, and external dependencies. The number of Non-Human Identities, machine-to-machine interactions, and automated decisions in play now exceeds what existing management and oversight processes were designed to handle. Many of the threats identified in this report emerge from organizations adopting new technologies, services, and dependencies faster than they can effectively govern them. Several developments will shape what comes next:

AI-Enabled Attacks Will Become Harder to Distinguish from Legitimate Activity: Attackers are already using AI to improve reconnaissance, phishing, and attack automation. The more consequential near-term shift is not speed but believability. AI-generated content, behavior, and identity signals can now pass controls designed for human-generated activity, making malicious activity more difficult to detect, increasing the likelihood of successful social engineering and fraud, and reducing the effectiveness of traditional detection and response techniques.

AI Systems Require Security Programs of Their Own: AI models, inference pipelines, and supporting infrastructure cannot be secured through general cloud controls alone. They introduce distinct failure modes, including prompt injection, data poisoning, and insecure tool integrations, that standard cloud security controls were not designed to address.

Identity Has Replaced the Network as the Primary Control Plane: Identity has displaced the network perimeter in most cloud environments. Service accounts, cryptographic identities, and federated trust relationships are areas where many items are still managed inconsistently or not at all.

Change Control Has Become a First-Order Security Problem: AI systems, IaC, and continuous deployment pipelines have accelerated the pace of change across cloud environments. Unreviewed changes to AI configurations, datasets, and infrastructure are now a primary mechanism through which security controls erode. Without validation, approval, and rollback capabilities keeping pace with modern deployment, organizations are effectively governing yesterday's environment.

Supply Chain Exposure Will Grow Faster Than Visibility: Dependence on external software, AI services, managed platforms, and cloud marketplaces is expanding. The monitoring and governance capabilities needed to detect when a dependency becomes a liability have not kept pace with the complexity of modern cloud ecosystems.

Complexity Is No Longer Just Operational Overhead. It Is a Security Condition: Multi-cloud architectures, AI systems, and rapidly changing deployment environments do not simply create more surface area. They create systemic blind spots that make it difficult to know what is running, what it has access to, and whether it is behaving as intended.

Four priorities follow from these findings:

Strengthen Identity Governance: Apply consistent governance to both human and non-human identities, including service accounts, agents, and federated trust relationships. Zero Trust principles, least privilege, and continuous verification apply to service accounts and agents as much as to human users.

Treat AI Systems as a Distinct Security Domain: Security programs need dedicated controls for model integrity, agent permissions, training data protection, and AI pipeline security. General cloud controls do not cover them.

Improve Change Control and Ecosystem Governance: Apply rigorous change management to cloud infrastructure, AI workloads, datasets, and third-party integrations. Independent review, automated validation, continuous monitoring, and rollback capabilities are not optional additions to change management. They are mechanisms by which unreviewed changes are caught before they become persistent exposures.

Build Visibility, Resilience, and Operational Awareness: Posture management, telemetry, observability, and centralized policy enforcement are only useful if they accurately reflect the current state of the environment they are monitoring.

As cloud environments increasingly incorporate autonomous AI capabilities, organizations should expect identity security, agent governance, runtime security monitoring, and AI-specific trust boundaries to become foundational elements of future cloud security programs. Agent governance establishes policies and decision authority for autonomous systems, while runtime security monitoring verifies that agent behavior continues to comply with policies during operation.

The organizations most exposed to the next generation of cloud threats are not necessarily those with weak perimeter controls. They are those whose governance, visibility, and change management practices have not kept pace with the complexity of the environments in which they operate. Closing that gap, across cloud infrastructure, AI systems, identities, and third-party dependencies, is the defining security challenge for the period ahead.

Appendix 1: Technical/Business Impacts and Key Takeaway Sections Content

To help readers navigate this paper, this appendix explains the content and format of its **Technical Impacts**, **Business Aspects**, and **Key Takeaways** sections.

The impact sections are taken from the **Cloud Security Alliance and ISACA's Certificate of Cloud Auditing Knowledge (CCAK)**. The key takeaways follow the content and format conventions used by the Top Threats Working Group in previous publications.

TECHNICAL IMPACT

The technical impacts of an attack on a system and its data compromise the system's confidentiality, integrity, and availability. Each impact category does not include the category definition, only the impact bullet points.

Confidentiality

Confidentiality ensures that information is protected from unauthorized access or disclosure.

Example:

- Disclosure of Data: Misconfigured storage, APIs, vector databases, or logging systems may expose sensitive data, including training datasets, embeddings, inference outputs, model artifacts, and internal logs.

Integrity

Integrity ensures that information is complete, accurate, up-to-date, and not subject to unauthorized modification or destruction, and that it is non-repudiable and authentic. This applies to data at rest, in transit, and during processing.

Example:

- Destruction or Corruption of Data: Improperly controlled changes or misconfigured workflows may corrupt or destroy datasets, model artifacts, or critical system data, affecting system integrity or recoverability.

Availability

Availability refers to ensuring that information, systems, facilities, networks, and computers are accessible to authorized individuals and groups when needed.

Example

- **Loss of Data or Service Availability:** Misconfigured storage systems, pipelines, lifecycle policies, automation processes, or infrastructure dependencies may result in accidental deletion, unavailability of critical cloud or AI data, degraded performance, or outages of cloud or AI services.

BUSINESS IMPACT

The business impact of any incident affecting the organization can be classified into four categories: financial, operational, compliance, and reputation.

Financial

Financial impacts include direct cost increases resulting from an incident — including compensation, technical investigations, ransomware, system upgrades, insurance premium increases, litigation costs, increased financing costs, reduced investment, and recruitment costs.

Example

- **Lost Revenue:** Service disruption, degraded performance, or loss of customer confidence may result in financial losses.

Operational

Operational impacts concern disruptions to business processes, systems, and data. Examples include reduced sales of products and services and production/service delays. BOMs (Bills of Materials), production/service planning files, product/service quality, product/service delivery, new product/service introduction, and production/service reporting systems may be corrupted.

Example

- **System Performance:** Incorrect configurations may degrade cloud service reliability, throughput, latency, or AI inference performance.

Compliance

Compliance impacts result from not complying with applicable laws and regulations. Two examples of such laws are the EU GDPR and HIPAA.

Example

- **Regulatory Violations:** Misconfigured cloud or AI environments may violate data protection, privacy, cybersecurity, or industry-specific regulatory requirements.

Reputational

Reputational impacts relate to perceptions of the company as a whole but lean toward internal factors — including management issues and brand value — and stakeholders' perceptions of products, services, and processes owned, licensed, or provided by an organization. In practice brand value and reputation are often used interchangeably. These impacts result in financial consequences. Examples of reputational impacts include damaged public perception, damaged customer and supplier relationships, reduced business opportunities, recruitment difficulties, loss of key staff, and media scrutiny.

Example

- **Company Reputation:** Public disclosure of cloud or AI misconfigurations may damage the organization's public image, customer trust, and brand value.

KEY TAKEAWAYS

A key takeaway is a significant point or lesson learned from incident analysis. It often relates to a particular control issue, general best practices, or recommendations related to incident management, and points to a solution for an issue or challenge.

Examples

- Vet third-party security service providers to ensure they are trustworthy and follow standard security practices.
- Require SLAs/contracts which provide additional network and filtering capacity during emergencies such as DDoS attacks.
- Recall that the least privilege principle and segregation of duties are key to incident prevention.
- Have a detailed, tested incident response plan ready.